



网络安全技术及应用

(第5版, 慕课微课版, 新形态)

贾铁军 何道敬 罗宜元 主编
古乐声 王威 张书台 副主编
王坚 陈国秦 参编

 **机械工业出版社**
CHINA MACHINE PRESS

第4章 黑客攻击与检测防御

回顾

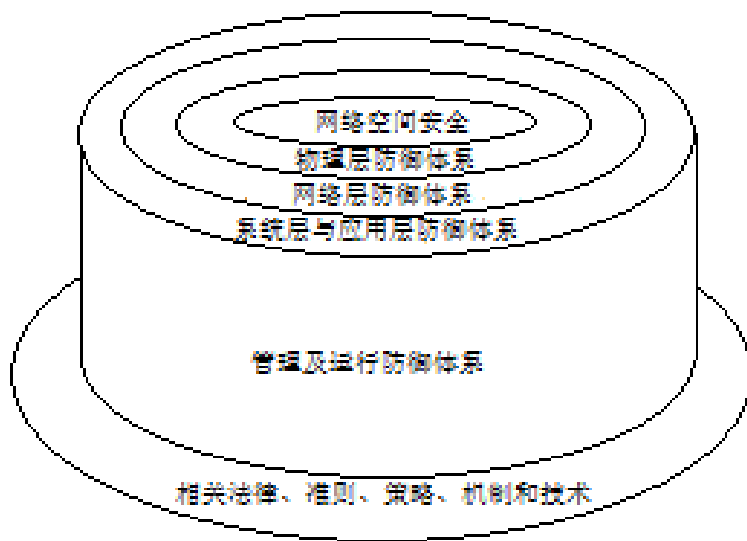


图3-3 网络空间安全防御体系

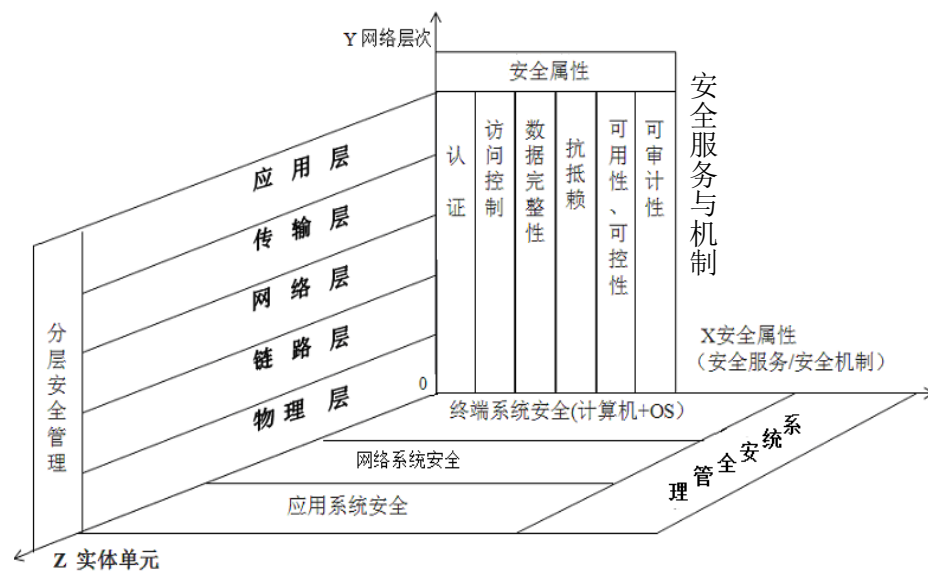


图3-4 TCP/IP网络安全管理体系结构

回顾

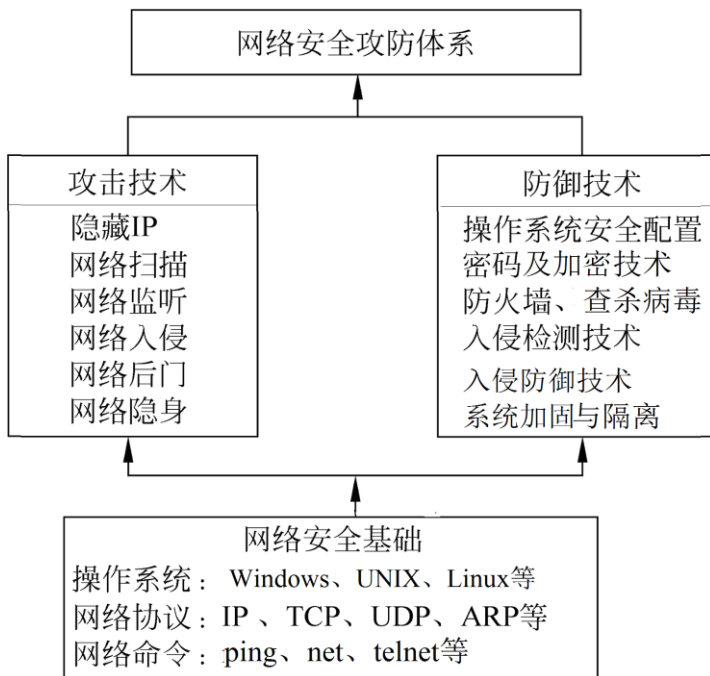


图3-5 网络安全攻防体系结构

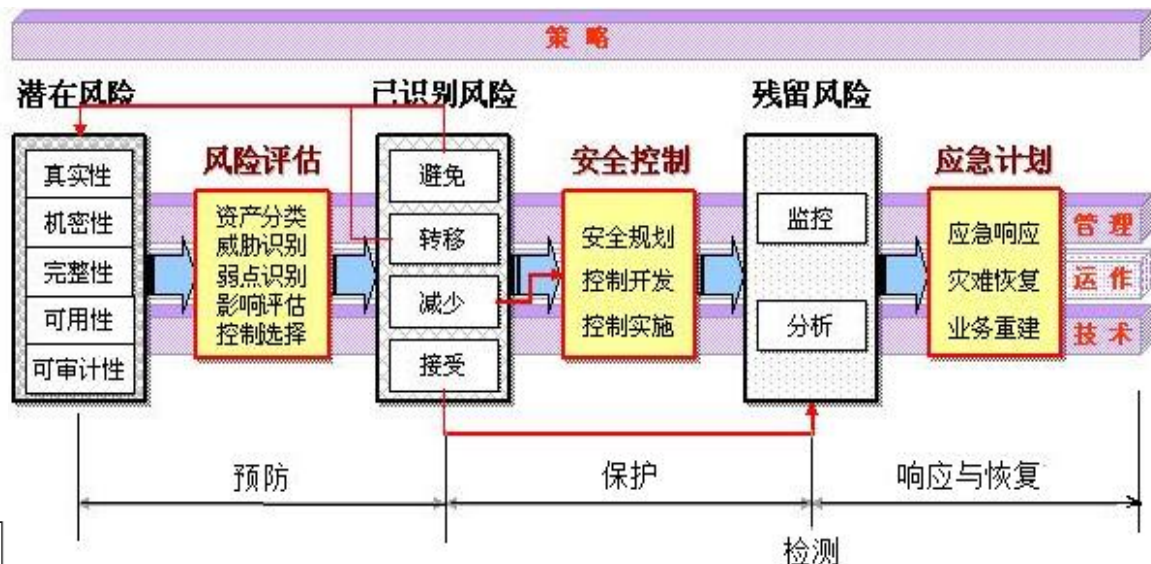


图3-6 网络安全保障体系



图3-7 网络安全保障要素

回顾

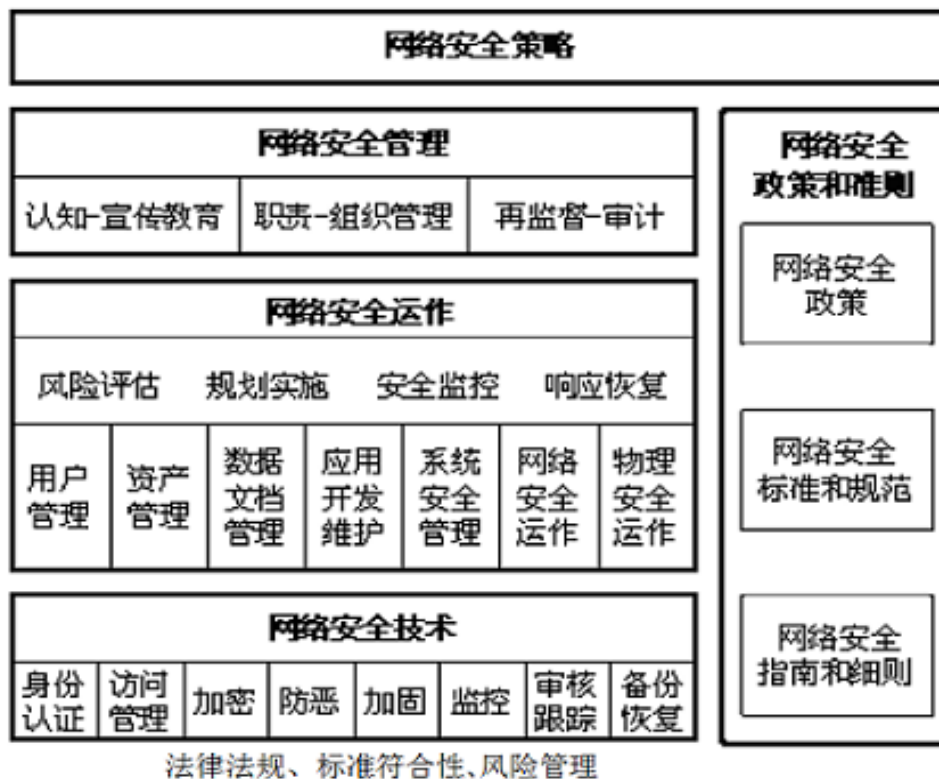


图3-9 网络安全保障体系框架

回顾

2006公安部
修订并实施

表3-3我国计算机信息系统安全保护等级划分

自主保护级

指导保护级

监督保护级

强制保护级

专控保护级

等级	名称	描述
第一级	用户自我保护级	安全保护机制可以使用户具备安全保护的能力，保护用户信息免受非法的读写破坏。
第二级	系统审计保护级	除具备第一级所有的安全保护功能外，要求创建和维护访问的审计跟踪记录，使所有用户对自身行为的合法性负责
第三级	安全标记保护级	除具备前一级所有的安全保护功能外,还要求以访问对象标记的安全级别限制访问者的权限,实现对访问对象的强制访问
第四级	结构化保护级	除具备前一级所有的安全保护功能外，还将安全保护机制划分为关键部分和非关键部分，对关键部分可直接控制访问者对访问对象的存取，从而加强系统的抗渗透能力
第五级	访问验证保护级	除具备前一级所有的安全保护功能外，还特别增设了访问验证功能，负责仲裁访问者对访问对象的所有访问

目 录

1

4.1 黑客概念及攻击途径

2

4.2 黑客攻击的目的及过程

3

4.3 常用的黑客攻防技术

4

4.4 网络攻击的防范措施

5

4.5 入侵检测与防御系统概述

6

* 4.6 实验1 Sniffer网络检测

7

4.7 本章小结



教学目标

□ 教学目标

- 理解黑客的相关概念、类型及攻击途径
- 掌握黑客攻击的主要目的、种类和过程
- 掌握常见黑客攻防技术和主要方式方法
- 理解入侵检测与防御系统的功能和应用
- 学会网络扫描系统加固防范操作实验

重点

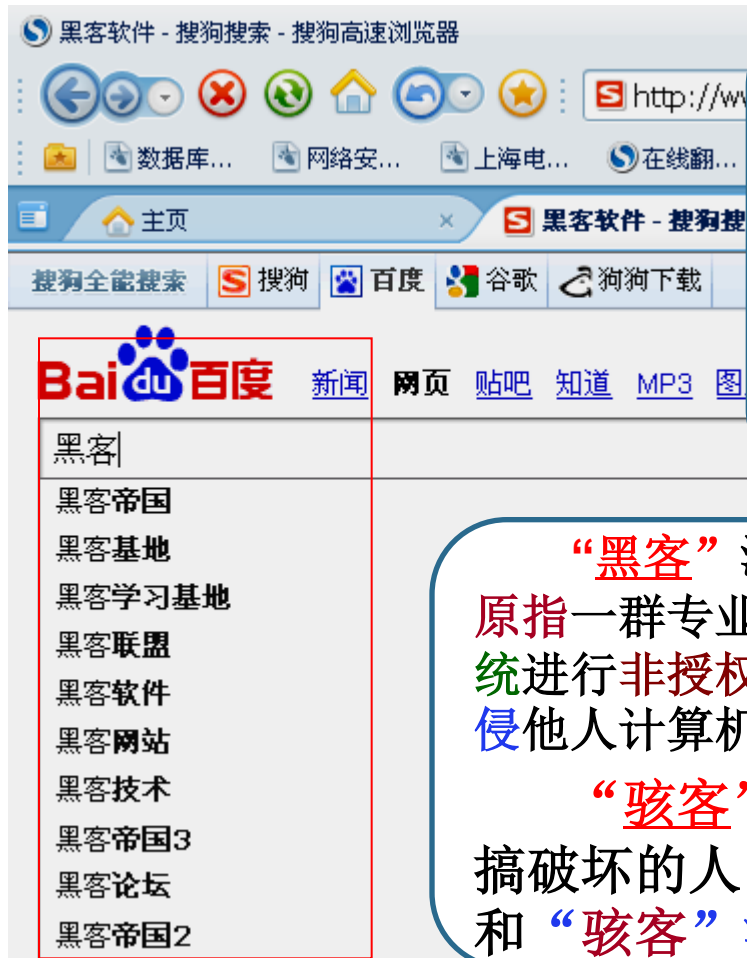
重点



4.1 黑客概念及攻击途径

4.1.1 黑客的概念及形成

1. 黑客的概念



案例4-1

美国国家安全局攻击西北工业大学。我国计算机病毒应急处理中心和360公司2022年9月发布调查报告，美国国家安全局NSA下属特定入侵行动办公室TAO，采用41种不同专属网络攻击武器，持续对西北工业大学开展攻击并窃密机密。先后利用日本、韩国等多国的跳板主机和17个国家的54台代理服务器实施攻击和窃密活动，用以掩盖真实IP并“借刀杀人”。

“**黑客**”源于英文**Hack**，本意为“干了一件非常漂亮的事”。原指一群专业技能超群、聪明能干、精力旺盛、对**计算机信息系统**进行**非授权访问**的人。后来成为专门利用计算机进行**破坏或入侵**他人计算机系统的人的**代名词**。

“**骇客**”是英文“**Cacker**”的译音，意为“破译者和搞破坏的人”。**骇客**的出现玷污了**黑客**，使人们把“**黑客**”和“**骇客**”混为一体。

4.1 黑客概念及攻击途径

2. 黑客的类型

黑客常分为红客、破坏者和间谍三种类型，红客是指“国家利益至高无上”的、正义的“网络大侠”；破坏者也称“骇客”；间谍指“利益至上”情报“盗猎者”。

也有将黑客分为“正”、“邪”两类，也就是经常听说的“黑客”和“红客”。



林勇

4.1 黑客概念及攻击途径

3. 黑客的形成与发展

案例4-2

20 世纪60 年代，在美国麻省理工学院的人工智能实验室里，有一群自称为黑客的学生们以编制复杂的程序为乐趣，当初并没有功利性目的。此后不久，连接多所大学计算机实验室的**美国国防部实验性**网络**APARNET**建成，**黑客活动便通过网络传播到更多的大**
学乃至社会。后来，有些人利用手中掌握的“绝技”，借鉴盗打免费电话的手法，擅自闯入他人的计算机系统，干起隐蔽活动。随着**APARNET** 逐步发展成为因特网，黑客们的活动天地越来越广阔，人数也越来越多，**形成**
鱼目混珠的局面。



4.1 黑客概念及攻击途径

4.1.2 黑客攻击的主要途径

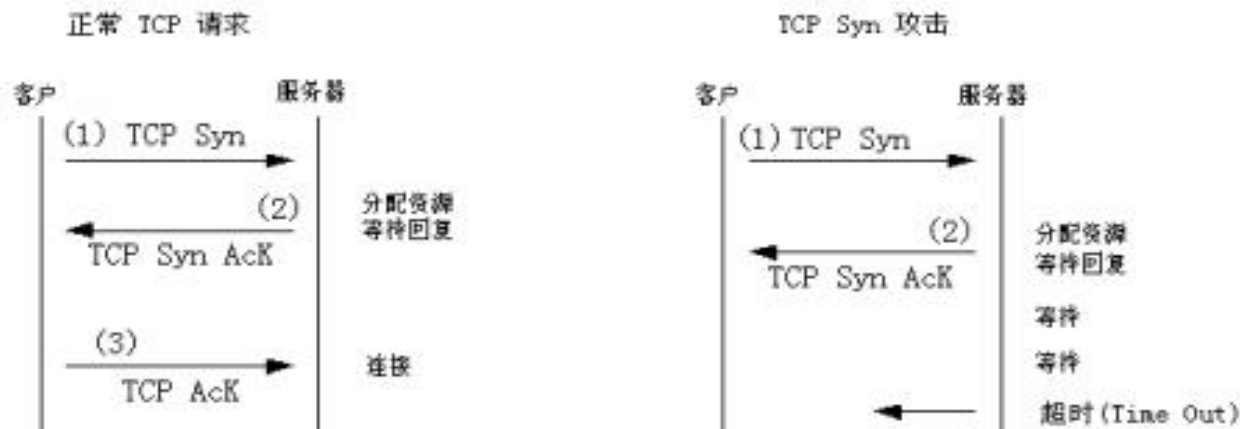
1. 黑客攻击的漏洞

体现：协议、系统、路由、传输、DB、技术、管理及法规等

系统漏洞又称缺陷。漏洞是在硬件、软件、协议的具体实现或系统安全策略上存在的缺陷，从而使攻击者能够在未授权的情况下访问或破坏系统。

造成漏洞的原因分析如下：

1) 协议漏洞：各种网络协议本身的缺陷。



4.1 黑客概念及攻击途径

4.1.2 黑客攻击的主要途径

1. 黑客攻击的漏洞

体现: 协议、系统、路由、传输、DB、技术、管理及法规等

2) 软件漏洞：系统研发的缺陷。

操作系统基础设计疏忽、源代码错误（缓冲区、堆栈溢出及脚本漏洞等）、安全策略施行误差、安全策略对象歧义问题）、**SQL注入**

```
// 有漏洞的fingerd代码片段 (简化)
void vuln_function(char *input) {
    char buffer[512];          // 固定大小缓冲区
    strcpy(buffer, input);     // 危险! 不检查输入长度
    // 如果input > 512字节, 将覆盖栈上的返回地址
}

// 攻击者构造的恶意输入:
// [512字节填充数据] + [4字节覆盖返回地址] + [Shellcode机器码]
```



4.1 黑客概念及攻击途径

4.1.2 黑客攻击的主要途径

1. 黑客攻击的漏洞

体现: 协议、系统、路由、传输、DB、技术、管理及法规等

2) 软件漏洞：系统研发的缺陷。

操作系统基础设计疏忽、源代码错误（缓冲区、堆栈溢出及脚本漏洞等）、安全策略施行误差、安全策略对象歧义问题）、**SQL注入**

-- 正常登录查询（存在漏洞的代码）

```
SELECT * FROM users WHERE username = '$username' AND password = '$password';
```

-- 攻击者输入：

用户名: admin' OR '1'='1' --

密码: 任意

-- 实际执行的SQL：

```
SELECT * FROM users WHERE username = 'admin' OR '1'='1' --' AND password = '任意';
```

-- 结果：-- 注释掉密码检查，OR条件永远为真，返回所有用户

4.1 黑客概念及攻击途径

4.1.2 黑客攻击的主要途径

1. 黑客攻击的漏洞

体现: 协议、系统、路由、传输、DB、技术、管理及法规等

3) 配置漏洞: 系统配置不当。

4) 人为漏洞: 系统安全管理中的问题。
管理人员或策略管理疏忽。

```
// MongoDB默认配置文件 mongod.conf (危险版本)
net:
  bindIp: 0.0.0.0           // 监听所有接口 (应为127.0.0.1或内网IP)
  port: 27017              // 默认端口 (未修改)

security:
  authorization: disabled // 禁用身份验证 (应为enabled)
```


4.1 黑客概念及攻击途径

■ 2. 网络端口通道 — 入侵窗口

网络端口是指网络中面向连接/无连接服务的通信协议端口, 是一种抽象的软件结构, 包括一些数据结构和I/O缓冲区。计算机通过端口实现与外部通信的连接/数据交换, 黑客攻击是将系统和网络设置中的各种(逻辑)端口作为入侵通道.

端口号: 端口通过端口号标记 (只有整数), 范围:

0~65535 ($2^{16}-1$)

目的端口号: 用于通知传输层协议将数据送给具体处理软件

源端口号: 一般是由操作系统动态生成的号码:

1024 ~ 65535

4.1 黑客概念及攻击途径

* 端口的分类

按端口号分布可分为三段:

1) 公认端口 (0~1023), 又称常用端口, 为已经或将要公认定义的软件保留的. 这些端口紧密绑定一些服务且明确表示了某种服务协议. 如80端口表示HTTP协议(Web服务).

2) 注册端口 (1024~49151), 又称保留端口, 这些端口松散绑定一些服务。

3) 动态/私有端口(49152~65535). 理论上不为服务器分配.

按协议类型将端口划分为TCP和UDP端口:

1) TCP端口需要在客户端和服务端之间建立连接, 提供可靠的数据传输. 如Telnet服务的23端口, SMTP默认25。

2) UDP端口不需要在客户端和服务端之间建立连接. 常见的端口有DNS服务的53端口。

FTP服务通过TCP传输, 默认端口20数据传输, 21命令传输

4.1 黑客概念及攻击途径

- 端口号: 21 服务: FTP (文件传输协议)
- 端口号: 22 服务: SSH (安全外壳协议)
- 端口号: 23 服务: Telnet (远程登录协议)
- 端口号: 25 服务: SMTP (简单邮件传输协议)
- 端口号: 53 服务: DNS (域名系统)
- 端口号: 67/68 服务: DHCP (动态主机配置协议)
- 端口号: 80 服务: HTTP (超文本传输协议)
- 端口号: 110 服务: POP3 (邮局协议版本3)
- 端口号: 123 服务: NTP (网络时间协议)
- 端口号: 143 服务: IMAP (Internet消息访问协议)
- 端口号: 161/162 服务: SNMP (简单网络管理协议)
- 端口号: 443 服务: HTTPS (安全超文本传输协议)
- 端口号: 465 服务: SMTPS (SMTP安全协议)
- 端口号: 873 服务: rsync (远程同步)
- 端口号: 989/990 服务: FTPS (SSL/TLS加密FTP)
- 端口号: 993 服务: IMAPS (IMAP安全协议)
- 端口号: 995 服务: POP3S (POP3安全协议)

```
nmap -sS -sV -O target_ip # SYN扫描+版本探测+OS探测
nmap -A target_ip         # 全面扫描
```

4.1 黑客概念及攻击途径

■ 3. 人为及管理疏忽— 社会工程学

社会工程学，是网络安全工作中一个最容易被忽略和最脆弱的环节。对于网络安全事件的分析，我们经常提到“三分技术七分管理”，这里的“管理”就是经常忽略的社会工程学。（人是任何安全系统中最薄弱的环节，也叫对人的黑客攻击）

案例

1. 重复请求权限；（心理）
2. 钓鱼链接或邮件；（心理）
3. 根据社交媒体，破获用户密码；（隐私）
4. 社工库。（隐私）📖（图寻）

4.1 黑客概念及攻击途径



4.1 黑客概念及攻击途径

STRAVA

vendredi 13 mars 2026

Arthur – Course à pied

7,23 km

Distance

35:58

Durée de
déplacement

4:58 /km

Allure

Dénivelé positif

2 m

Calories

535

Temps écoulé

37:20

Garmin Forerunner 955

Athènes

Denizli

Konya

Antalya

Mersin

Gaziantep

Alep

Chypre

Liban

Israël

300m

Egypte

Port Saïd

Jordanie

法国水兵健身APP晒记录暴露戴高乐航母位置；正位于地中海东部，塞浦路斯岛的西北方向，距离土耳其海岸大概一百公里左右的海域

4.1 黑客概念及攻击途径

■ 3. 人为及管理疏忽— 社会工程学

社会工程学，是网络安全工作中一个最容易被忽略和最脆弱的环节。对于网络安全事件的分析，我们经常提到“三分技术七分管理”，这里的“管理”就是经常忽略的社会工程学。（人是任何安全系统中最薄弱的环节，也叫对人的黑客攻击）



讨论思考：

- (1) 什么是安全漏洞和隐患？网络为何存在安全漏洞和隐患？
- (2) 举例说明，计算机网络安全面临的黑客攻击问题。
- (3) 黑客通道 -- 端口主要有哪些？特点是什么？
- (4) 社会工程学在信息安全领域的应用有哪些？

4.2 黑客攻击的目的及过程

4.2.1 黑客攻击的目的及种类

1. 黑客攻击的目的

案例4-3

360安全捕获美中央情报局CIA对我国长达11年的网络攻击。包括航空航天、科研机构、石油、大型互联网公司和政府机构等均遭到不同程度的攻击。还定位到负责从事研发和制作相关网络武器的CIA前雇员约书亚·亚当·舒尔特(Joshua Adam Schulte)，在CIA的秘密行动处(NCS)担任科技情报主管职位，直接参与研发了针对我国攻击的网络武器Vault7（穹窿7）。

黑客实施攻击目的：

其一，为了**得到财物利益**；是指**获取金钱财物**；

其二，为了**满足精神需求**。是指**满足个人心理欲望**。

黑客行为：攻击网站；**盗窃**资料；**进行恶作剧**；**告知漏洞**；**获取**目标主机系统的非法访问权等。

4.2 黑客攻击的目的及过程

4.2.1 黑客攻击的目的及种类

1. 黑客攻击的目的



黑客实施攻击目的：

其一，为了**得到财物利益**；是指**获取金钱财物**；

其二，为了**满足精神需求**。是指**满足个人心理欲望**。

黑客行为：攻击网站；**盗窃**资料；**进行恶作剧**；**告知漏洞**；**获取**目标主机系统的非法访问权等。

4.2 黑客攻击的目的及过程

4.2.1 黑客攻击的目的及种类

2. 黑客攻击手段的种类

- 1) 网络监听。也称网络嗅探。最初用于网络管理员用于监听网络情况，后来逐渐被黑客利用，用于监听嗅探对方的网络传输信息。
- 2) 拒绝服务攻击。是黑客利用发送庞杂垃圾文件、数据包或请求，导致目标网站因疲于处理而无法提供正常服务、导致系统崩溃或资源耗尽，最终使网络拥塞或瘫痪的攻击手段。
- 3) 欺骗攻击
 - ① ARP欺骗；
 - ② IP欺骗；
 - ③ 域名欺骗；
 - ④ Web欺骗；
 - ⑤ 邮件欺骗。
- 4) 密码及病毒攻击。黑客主要利用破获密码或病毒软件等方式攻击，包括多种密码获取及工具方式、木马（病毒）远程攻击等。他们设法窃取系统或资源访问权，实施攻击后为再次入侵种植后门插件。

4.2 黑客攻击的目的及过程

4.2.1 黑客攻击的目的及种类

2. 黑客攻击手段的种类

案例4-4

新型勒索病毒Coffee潜伏期高达百日。

2022年2月,国家计算机病毒应急处理中心通过对互联网的监测,名为**Coffee**勒索病毒通过钓鱼邮件、**QQ**群附件等方式传播,高校和研究所等是攻击主要目标。该病毒可通过被感染用户的**QQ**自动发送带有勒索病毒的消息,进行蠕虫式传播。还会感染已有软件微信、**QQ**、**WPS**、**Edge**浏览器、优酷、爱奇艺、百度网盘等,将病毒宿主和其恶意dll释放到目标程序安装目录下,可随目标程序启动加载。

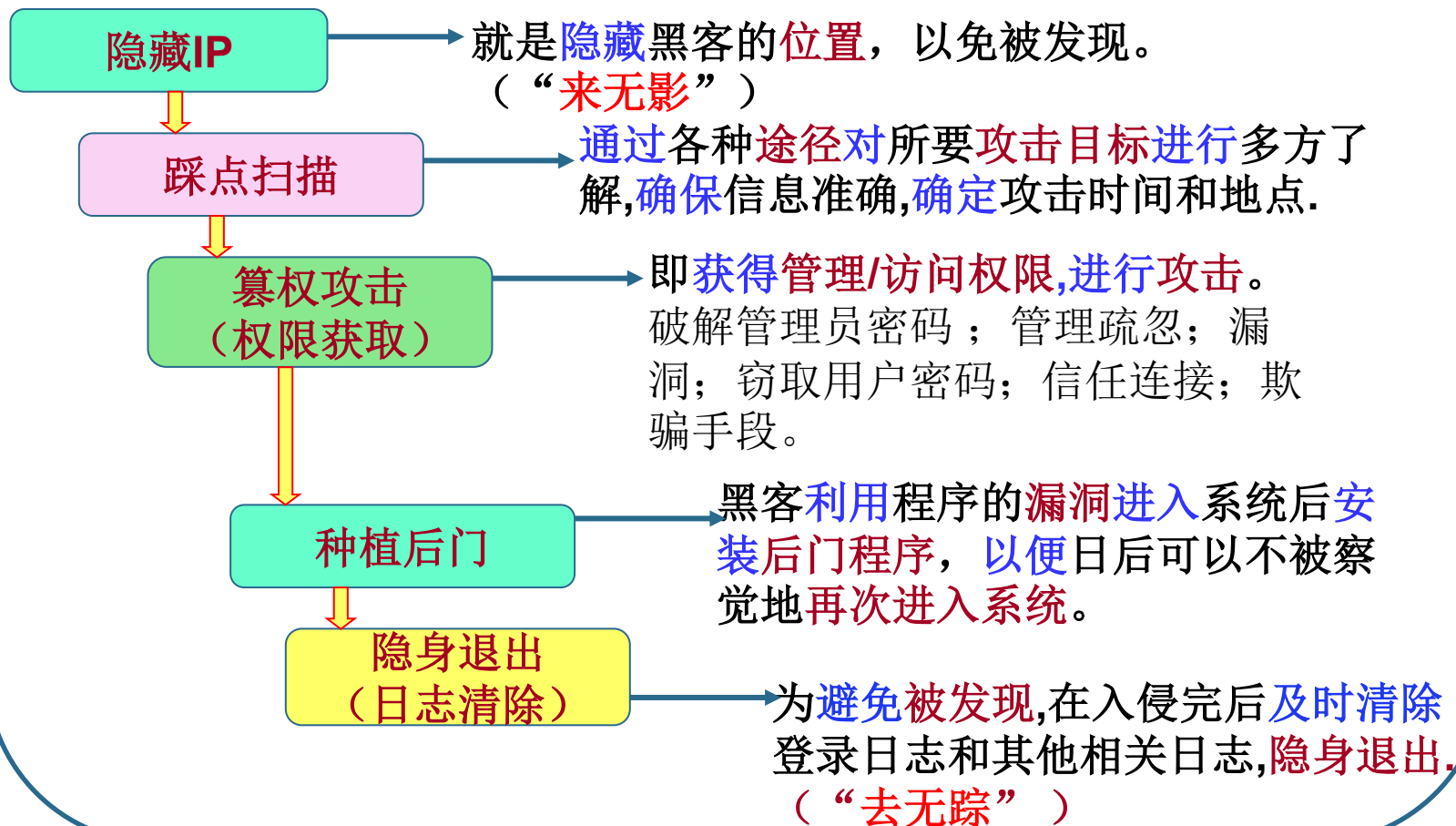
5) 应用层攻击。主要针对各种应用与服务采用多种不同攻击方式通常针对服务器或主机应用软件漏洞,获得登陆及账户权限实施攻击。

6) 缓冲区溢出。向系统的缓冲区写超长内容,造成缓冲区溢出,从而破坏程序的堆栈,使程序转而执行其他指令。当这些指令进入具有**Root**权限的内存并运行后,黑客就可以获得程序的控制权,以**Root**权限控制系统,达到攻击目的。

4.2 黑客攻击的目的及过程

4.2.2 黑客攻击的基本过程

黑客攻击步骤各异,但其整个攻击过程有一定规律,一般可分为“攻击五步曲”。



4.2 黑客攻击的目的及过程

4.2.2 黑客攻击的基本过程

隐藏IP

→ 就是隐藏黑客的位置，以免被发现。
(“来无影”)

目的：隐藏黑客的真实位置，避免被追踪

举例：

- 使用**VPN**：黑客连接到国外的VPN服务器，让目标网站记录的是VPN服务器的IP地址
- 使用**Tor浏览器**：通过多层加密和节点跳转，层层隐藏真实IP
- 使用**代理服务器链**：先连接日本代理，再转新加坡，最后才攻击目标
- 使用“肉机”：傀儡机

实际案例：某黑客攻击美国政府网站时，先连接到俄罗斯的VPN，再经过多个国家的代理服务器，让调查人员难以追踪到真实来源。

4.2 黑客攻击的目的及过程

4.2.2 黑客攻击的基本过程

踩点扫描

通过各种途径对所要攻击目标进行多方了解,确保信息准确,确定攻击时间和地点.

目的：全面了解目标，确定攻击时机和方式

举例：

端口扫描：使用Nmap工具扫描目标服务器开放了哪些端口（如80网页端口、22SSH端口、3389远程桌面端口）

网站信息收集：查看目标网站的备案信息、使用的技术框架（如WordPress、Apache）

社会工程学：在LinkedIn上查找目标公司员工信息，了解内部系统架构

WHOIS查询：查询域名注册信息，获取管理员联系方式和服务器地址

实际案例：黑客发现某公司网站使用旧版本的Apache服务器（存在已知漏洞），并发现管理员邮箱，准备发送钓鱼邮件。

4.2 黑客攻击的目的及过程

4.2.2 黑客攻击的基本过程

篡权攻击
(权限获取)

→ 即获得管理/访问权限, 进行攻击。
破解管理员密码；管理疏忽；漏洞；窃取用户密码；信任连接；欺骗手段。

目的：获得系统的管理或访问权限

举例：

破解密码：使用暴力破解工具尝试管理员账号的弱密码（如admin/123456）

利用漏洞：利用Apache服务器的CVE漏洞上传木马文件

SQL注入：在登录框输入 ' OR '1'='1 绕过身份验证

钓鱼邮件：发送伪装成IT部门的邮件，骗取员工账号密码

中间人攻击：在公共WiFi中截获用户的登录凭证

实际案例：黑客发现某网站登录页面存在SQL注入漏洞，通过构造特殊语句 ' UNION SELECT * FROM admin-- 直接获取了管理员账号密码。

4.2 黑客攻击的目的及过程

4.2.2 黑客攻击的基本过程

种植后门

黑客利用程序的漏洞进入系统后安装后门程序，以便日后可以不被察觉地再次进入系统。

目的：在系统中留下"暗门"，方便日后再次进入

举例：

WebShell：上传一个伪装成图片的PHP文件（如logo.jpg.php），实际上是可以执行命令的后门

创建隐藏账号：添加一个名为 `adm1n` 的管理员账号，看起来像系统账号

修改系统文件：替换系统的远程登录程序，加入自己的密码验证

计划任务：设置定时任务，每天自动连接黑客的控制服务器

实际案例：黑客在某公司服务器上植入了一个名为 `system_update.exe` 的程序，实际上每24小时就会自动向黑客发送服务器的最新IP地址和状态。

4.2 黑客攻击的目的及过程

4.2.2 黑客攻击的基本过程

隐身退出
(日志清除)

→ 为**避免被发现**,在入侵完后**及时清除**登录日志和其他相关日志,**隐身退出**.
(“去无踪”)

目的: 清除入侵痕迹, 避免被发现

举例:

删除日志文件: 清空Windows的事件查看器日志或Linux的/var/log/目录

修改日志内容: 只删除与自己操作相关的记录, 保留其他正常日志以免引起怀疑

恢复文件时间戳: 将被修改的系统文件时间改回原始时间

使用反取证工具: 使用专门工具覆盖已删除文件的磁盘空间

实际案例: 某黑客在完成攻击后, 使用脚本自动清理了服务器上最近3天的SSH登录记录, 并将自己上传的后门文件修改时间调整为半年前, 让管理员以为是旧文件。

4.2 黑客攻击的目的及过程

黑客攻击企业内部局域网过程, 图4-1是攻击过程的示意图.



图 4-1 黑客攻击企业内部局域网的过程示意图

讨论思考:

- (1) 试说明黑客攻击“五步曲”的过程?
- (2) 黑客找到攻击目标后,可以继续那几步的攻击操作?
- (3) 黑客的行为有哪些?
- (4) 试比较黑客攻击的“来无影”和“去无踪”的异同点?

4.3 常用的黑客攻防技术

随着国际各种对抗和竞争加剧，以及网络新技术的快速发展，多种新型网络攻击手段变化多端，攻击防范技术和措施极为重要。需要对传统黑客攻防技术及新型攻防技术进行分析，常用黑客攻防技术如图4-2。

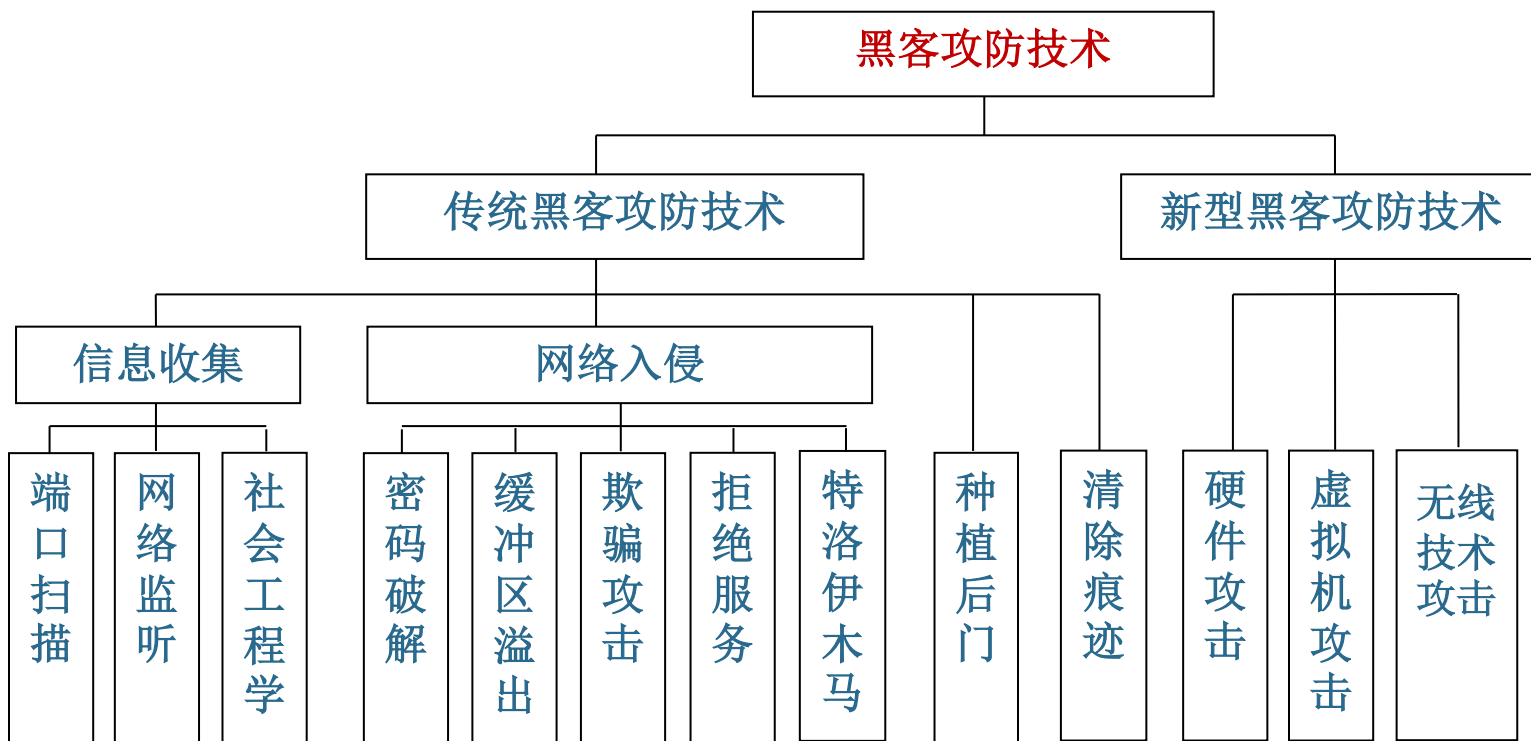


图4-2常用的黑客攻防技术

4.3 常用的黑客攻防技术

4.3.1 传统黑客攻防技术

1. 端口扫描攻防

端口是终端与外部通信传输的接口。

1) 端口**扫描工具**。端口扫描器也称扫描工具、扫描软件，是一种用于检测远程或本地主机或网段安全问题的软件。 

Nmap: 功能最全面的扫描工具，支持上述所有技术

Masscan: 极速扫描器，适合大规模互联网扫描

Zmap: 学术界开发的高速扫描工具

Unicornscaan: 分布式扫描框架



4.3 常用的黑客攻防技术

4.3.1 传统黑客攻防技术

- 2) 端口**扫描方式**。利用TCP端口的连接定向特性，根据与目标计算机某些端口建立的连接的应答，从而收集目标计算机的有用信息，发现系统的安全漏洞。

4.3 常用的黑客攻防技术

4.3.1 传统黑客攻防技术

1. 端口扫描攻防（按扫描技术分类）

1) TCP 扫描

- TCP Connect扫描：完成完整的三次握手；最可靠，但日志记录明显，易被检测。
- SYN 扫描（半开扫描）：只发送SYN，收到SYN+ACK后发送RST断开；快速、隐蔽，不建立完整连接。
- FIN/NULL/Xmas扫描：发送FIN/无标志位/URG+FIN+PSH包；可绕过某些无状态防火墙，但对Windows无效。
- ACK扫描：发送ACK包；主要用于判断端口是否被防火墙过滤。

2) UDP 扫描

- 发送UDP数据包到目标端口，无响应表示端口开放或被过滤，返回ICMP 不可达表示关闭；速度较慢，可靠性较低（因 ICMP 速率限制）



4.3 常用的黑客攻防技术

4.3.1 传统黑客攻防技术

1. 端口扫描攻防（按扫描策略分类）

- 全端口扫描：扫描 1-65535 所有端口（最彻底但最慢）
- 常用端口扫描：针对 1-1024 或常见服务端口（如 22, 80, 443, 3389 等）
- 定向扫描：根据目标特征扫描特定服务端口
- 随机扫描：随机顺序扫描，规避检测

4.3 常用的黑客攻防技术

4.3.1 传统黑客攻防技术

1. 端口扫描攻防（高级扫描技术）

- 分段扫描：将TCP头分片发送，绕过简单包过滤
- 源地址欺骗：伪造源IP地址
- Idle扫描（僵尸扫描）：利用第三方主机作为跳板，高度隐蔽
- FTP反弹扫描：利用FTP服务器的代理特性

4.3 常用的黑客攻防技术

4.3.1 传统黑客攻防技术

3) 端口扫描攻击与防范对策。采用探测技术, 黑客可用于寻找能够成功攻击的服务。



4.3 常用的黑客攻防技术

4.3.1 传统黑客攻防技术

3) 端口扫描攻击与防范对策。

- 对于系统管理员而言，可采取以下措施防范端口扫描：
 - 配置防火墙限制 ICMP 响应速率
 - 使用入侵检测系统（IDS）识别扫描行为
 - 关闭不必要的服务和端口
 - 部署端口敲门（Port Knocking）等隐蔽技术：服务端口默认关闭，需按特定顺序访问一组“敲门端口”后才开放
 - 蜜罐与欺骗：在常用端口部署监听服务，记录扫描者行为
 - 动态端口迁移：关键服务端口定期随机变化；结合 SDN（软件定义网络）动态重定向流量。

4.3 常用的黑客攻防技术

2. 网络监听攻防

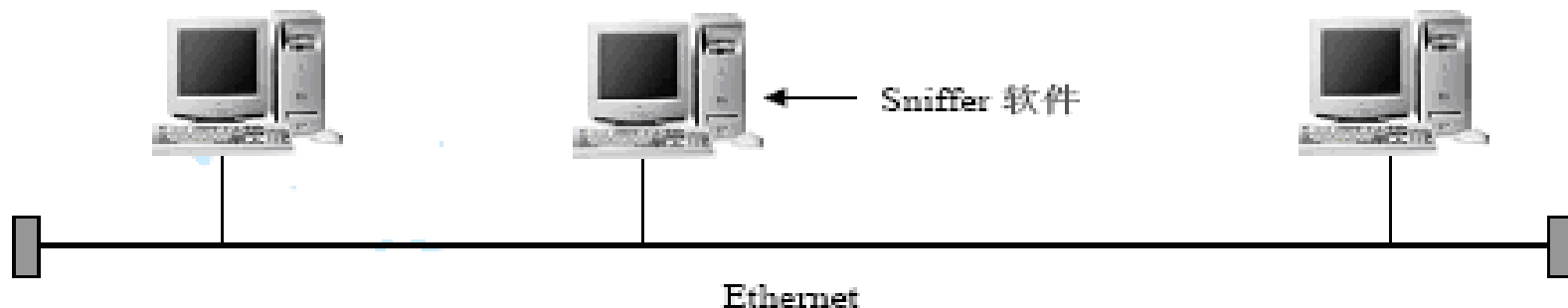
1) **网络监听**。网络监听也称网络嗅探，是通过技术手段监查网络状态，并截获指定网段数据流，以获取相关重要信息的一种方法。

注意：网络监听只限于局域网用于物理上连接同一网段的主机。

2) **网络监听检测**。是网络管理员检测网络的工具，用于监测网络传输数据和排除故障等。

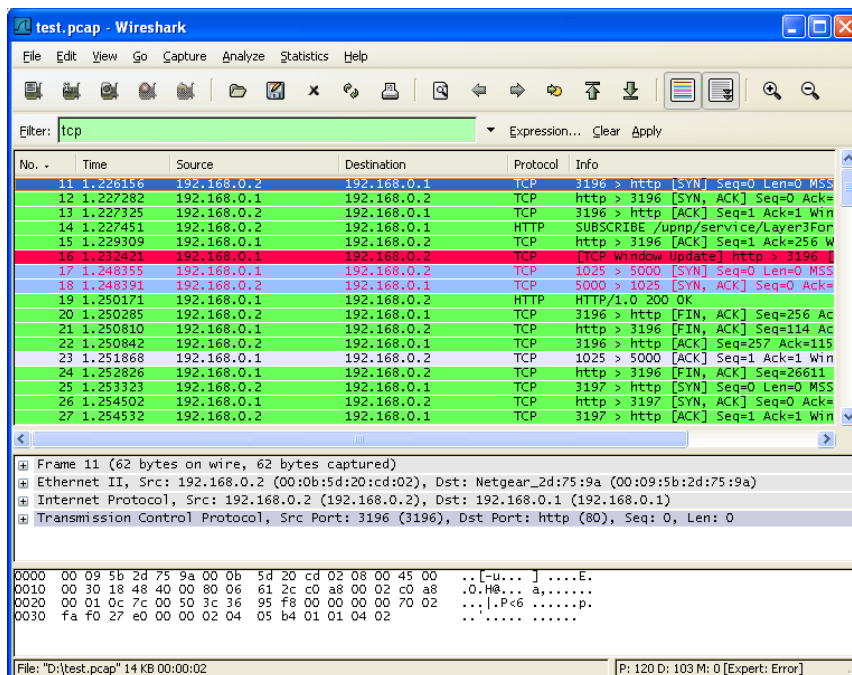
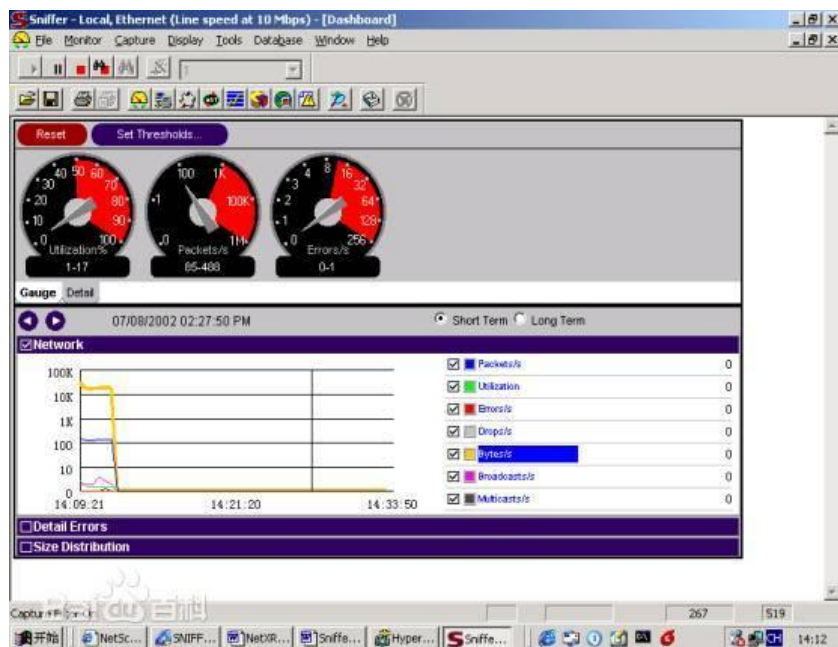
3) **网络监听防范**，主要包括：从逻辑/物理上对网络分段、以交换式集线器代替共享式集线器、密码加密技术、划分VLAN、使用动态口令技术等。

图4-3 Sniffer软件工作原理



4.3 常用的黑客攻防技术

Sniffer（嗅探器），又称抓数据包软件，是一种基于**被动侦听**原理的网络分析方式，通过将网卡设为**混杂模式**截获网络流量，支持对**400**余种协议进行解析，适用于有线网络、无线网络及光纤网络环境。其工作原理依赖交换机端口镜像或**ARP**欺骗技术实现交换网络中的数据捕获，可实时监控链路流量分布、应用协议占比及异常攻击行为，并提供专家系统辅助故障诊断。



4.3 常用的黑客攻防技术

3. 密码破解的防范对策

1) 密码攻击方法。

■ 暴力破解

- 原理：遍历所有可能的字符组合，直到试出正确密码
- 变种：字典攻击（使用常见密码列表）、掩码攻击（已知部分信息时缩小范围）
- 特点：理论上100%成功，但耗时与密码复杂度呈指数关系

■ 社会工程学攻击

- 钓鱼邮件/网站：伪装成可信实体骗取密码
- 假冒客服/技术支持：通过电话或即时通讯套取信息
- 肩窥/偷窥：直接观察他人输入密码

■ 凭证填充

- 原理：利用其他平台泄露的用户名-密码组合，批量尝试登录其他服务
- 前提：用户在不同平台使用相同密码

4.3 常用的黑客攻防技术

3. 密码破解的防范对策

1) 密码攻击方法。

■ 键盘记录器

- 原理：恶意软件记录用户的键盘输入，直接获取明文密码
- 传播方式：木马、恶意附件、感染的可移动设备

■ 中间人攻击

- 原理：拦截通信流量，窃取传输中的凭证（尤其在不安全的公共WiFi下）
- 工具：伪造热点、ARP欺骗、DNS劫持

■ 哈希破解

- 原理：获取数据库泄露的密码哈希值，通过彩虹表、GPU加速计算还原明文
- 前提：目标网站发生数据泄露且哈希算法较弱

■ 密码重置漏洞利用

- 原理：利用弱安全问题、可预测的验证码、未验证的邮箱/手机号等方式重置他人密码

4.3 常用的黑客攻防技术

■ 3. 密码破解的防范对策

2) 密码破解工具。用于破解密码的应用程序。

- Hydra: 网络登录密码爆破工具, 支持多种协议 (SSH、FTP、HTTP 等)。
- John the Ripper: 离线密码哈希破解工具, 支持多种加密算法。
- Hashcat: 高性能GPU加速破解工具, 支持复杂哈希算法。

4.3 常用的黑客攻防技术

3. 密码破解的防范对策

3) 密码防范要点。网络用户应注意“5不要”，包括：

- ①不要选取容易被黑客猜测的信息做密码，如生日、手机号等。
- ②不要将密码写到另处，容易造成泄露或遗失问题。
- ③不要将密码保存在电脑或其他磁盘文件中。
- ④不要向别人透露，以免带来不必要损失和麻烦。
- ⑤不要在多个重要系统使用同一密码，降低损失。

进行密码设置时，注意保护密码“三度”原则：

- 1) 密码系列的“复杂度”，如大小写、特殊字符、数字等的混搭组合。
- 2) 不同应用的密码“区分度”，近年来“撞库”攻击越来越多，用户对不同系统的密码设置，需要注意“区分度”。
- 3) 密码修改的“频度”，不超过三个月进行一次密码的更新。

4.3 常用的黑客攻防技术

3. 密码破解的防范对策

3) 密码防范要点。

策略	具体做法
账户锁定机制	连续失败登录后暂时锁定账户或增加验证码
登录速率限制	限制单位时间内的尝试次数，拖慢暴力破解
密码哈希加盐	使用bcrypt、Argon2、scrypt等现代算法，避免MD5/SHA1
实施零信任架构	持续验证身份，不默认信任任何访问
监控异常登录	检测异地登录、非常用设备、异常时间访问等行为
定期安全审计	渗透测试、代码审计、数据库加密

最小权限原则 → 只给必要的访问权限

纵深防御原则 → 多层保护，单点失效不崩溃

假设泄露原则 → 密码可能泄露，MFA是最后防线

4.3 常用的黑客攻防技术

4. 特洛伊木马的攻防

- 1) 特洛伊木马。**特洛伊木马 (Trojan Horse)** 简称“**木马**”，源于古希腊传说中特洛伊攻城典故。
- 2) 木马植入方式。主要利用点击链接、邮件或下载软件等。包括：网站植入、升级植入、漏洞植入、U盘植入、程序绑定等
- 3) 木马攻击过程。攻击途径：先通过客户端和服务端选择通信协议, 多数木马使用TCP/IP协议, 少数因特殊情况选择UDP协议。

木马攻击基本过程，分为6个步骤：配置木马、传播木马、运行木马、泄露信息、建立连接、远程控制。

案例4-9

国家互联网应急中心安全威胁报告：2022年7月，我国境内感染主机排名前五位的木马或僵尸网络主要是 Ramnit、Chacha等, 其感染的主机数量约占全部感染主机总数的88.2%。境内被篡改网站数量3,713个, 被篡改政府网站数量为22个; 境内被植入后门的网站数量为1,960个, 政府网站有17个; 针对境内网站的仿冒页面数量为7,740个; 国家信息安全漏洞共享平台 (CNVD) 收集整理信息系统安全漏洞2,066 个。其中, 高危漏洞730个, 可被利用来实施远程攻击的漏洞1,613个。



4.3 常用的黑客攻防技术

4) 防范对策和措施，木马防范对策和措施包括：

- ①提高安全防范意识，不要打开非信任或未确认安全的电子邮件及附件。应当标记信任用户或以纯文本方式阅读进行确认。
- ②在打开或下载文件之前，一定要确认文件来源安全可靠。
- ③安装和使用最新杀毒软件更新病毒库，选用有木马病毒拦截功能的杀毒软件。
- ④监测系统文件、注册表、应用进程和内存等变化，定期备份文件和注册表。
- ⑤特别注意不要运行未确认软件或从网上下载的软件，经过阅读确认后运行。
- ⑥及时更新系统漏洞补丁，及时升级更新系统软件和应用软件。
- ⑦不随意浏览陌生网站，包括网站广告、红包或不明链接等。
- ⑧在主机安装并运行防火墙或入侵检测防御系统等。

4.3 常用的黑客攻防技术



5. 拒绝服务攻防

案例4-7

DDoS攻击是最常见且影响最大的网络安全威胁。

由2020年上半年我国互联网网络安全监测数据分析报告发布的数据可知, 累计监测发现**用于发起DDoS攻击的活跃C&C控制服务器 2,379台**, 其中位于境外的占比95.5%, 主要来自美国、荷兰、德国等; **活跃的受控主机约 122 万台**, 其中来自境内的占比 90.3%, 主要来自江苏省、广东省、浙江省、山东省、安徽省等; **反射攻击服务器约 801 万台**, 其中来自境内的占比 67.4%, 主要来自辽宁省、浙江省、广东省、吉林省等。

1) **拒绝服务攻击DoS**。指黑客利用被控制的主机(肉鸡)向目标系统发送大量服务请求或垃圾文件等, 致使系统无法为合法用户提供正常服务, 甚至瘫痪或严重拥塞的攻击方式。**目的**是使目标系统无法服务或获取其控制权限。

分布式拒绝服务攻击(DDoS)是利用分布式网络DoS攻击, 以更大规模攻击系统。攻击原理如图4-4。

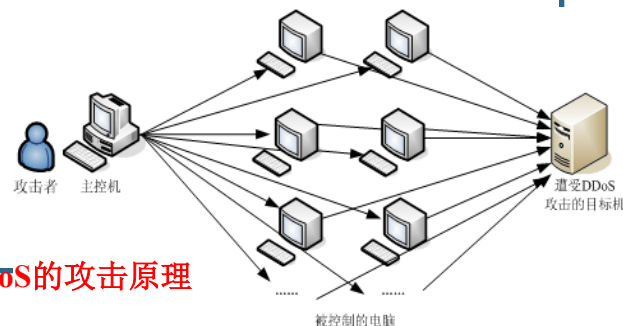


图4-4 DDoS的攻击原理

4.3 常用的黑客攻防技术

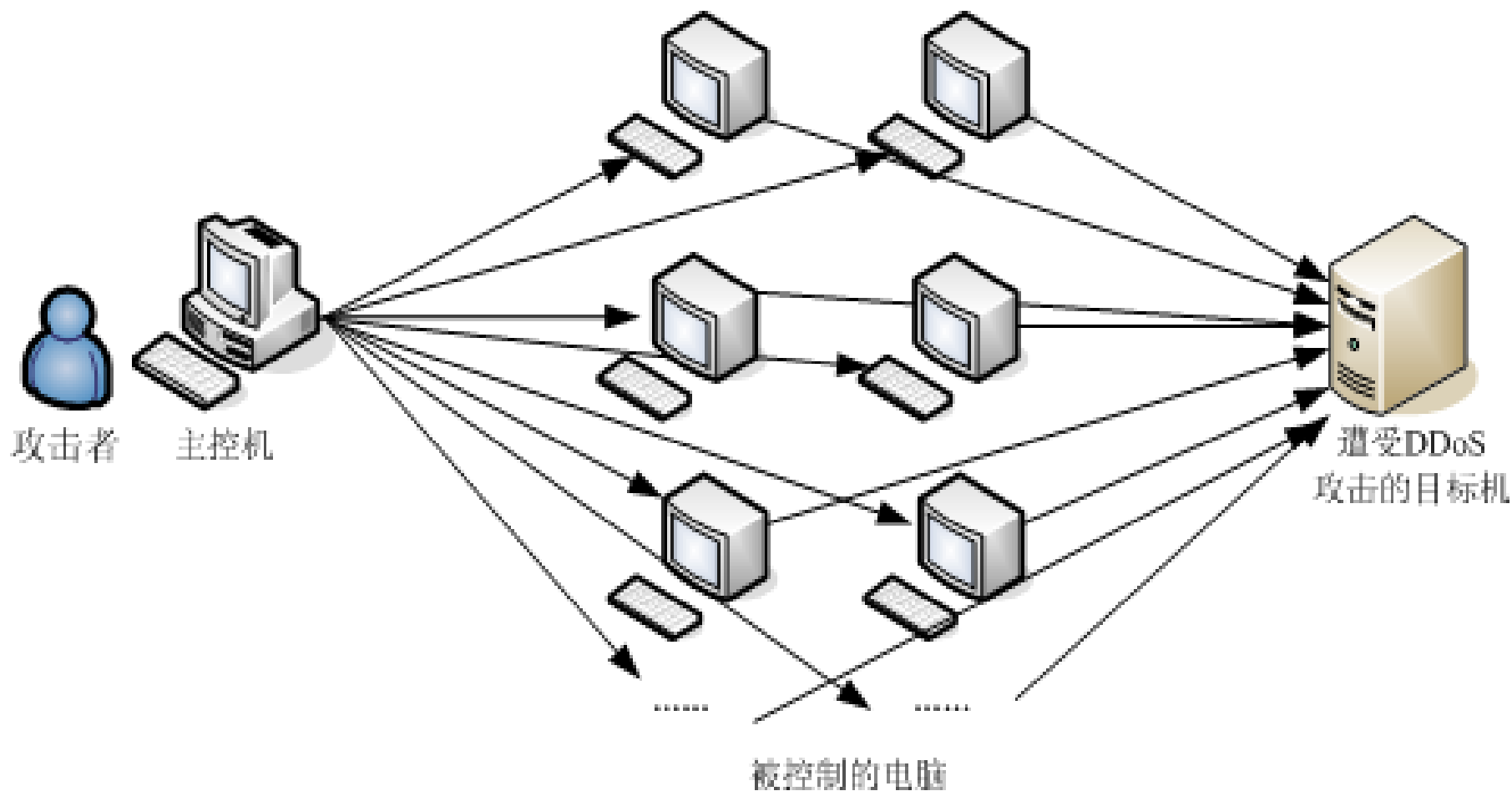


图4-4 DDoS的攻击原理

4.3 常用的黑客攻防技术

2) 常见的拒绝服务攻击。主要有5种。

① TCP SYN拒绝服务攻击。利用TCP/IP固有漏洞如图4-5。

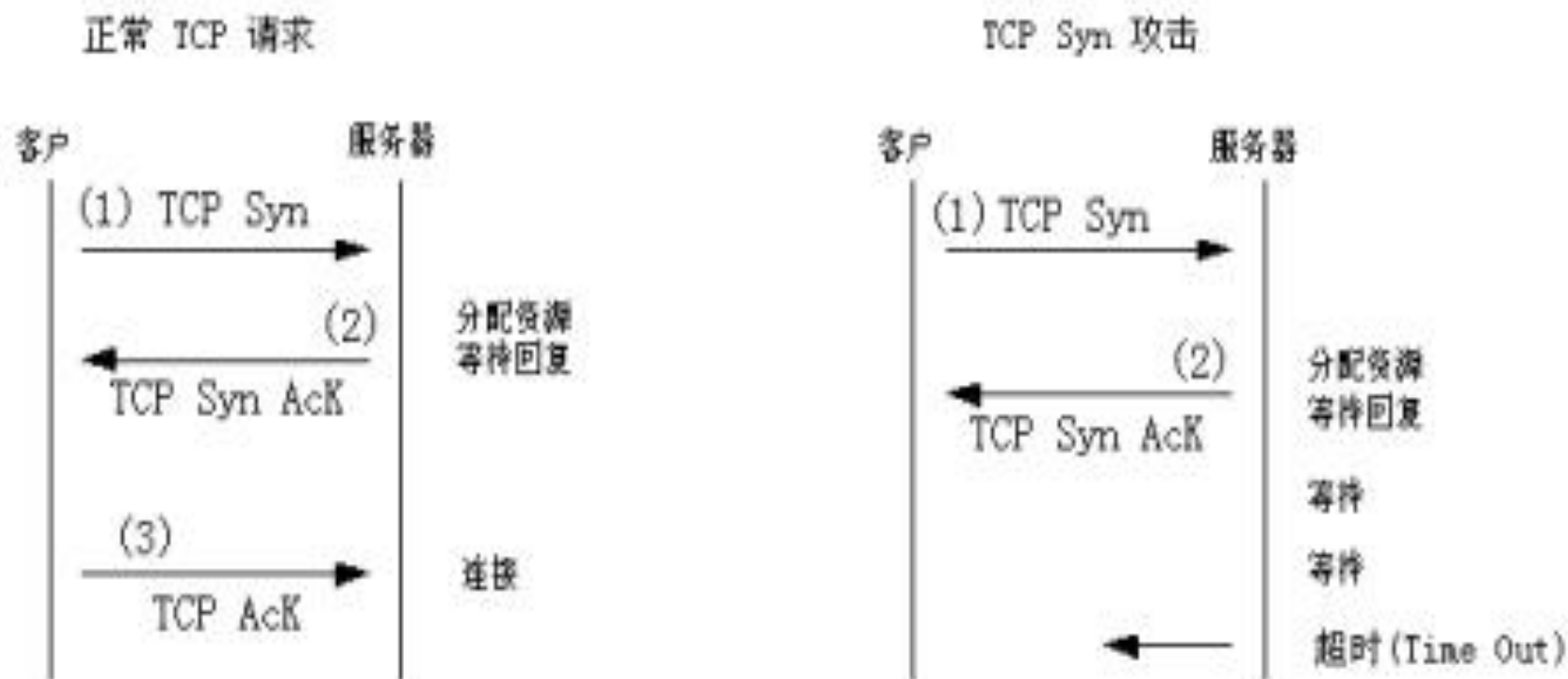
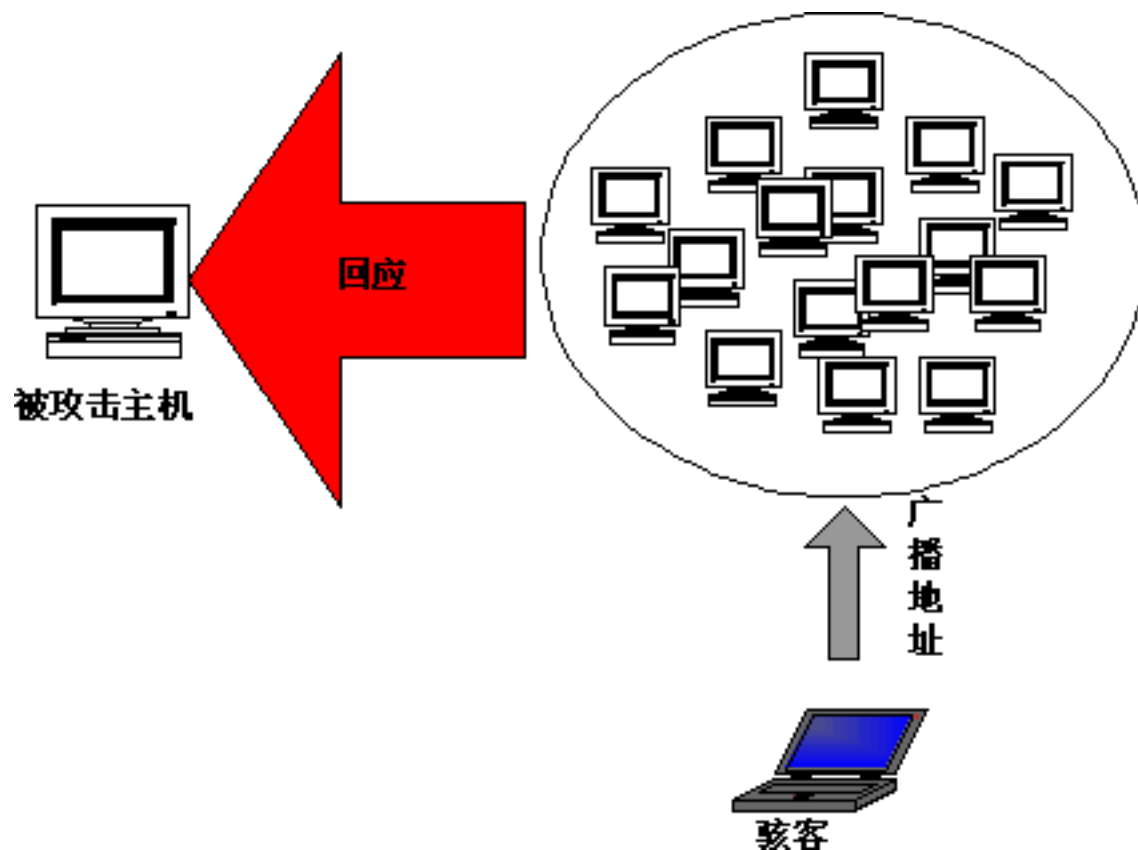


图4-5 TCP SYN拒绝服务攻击

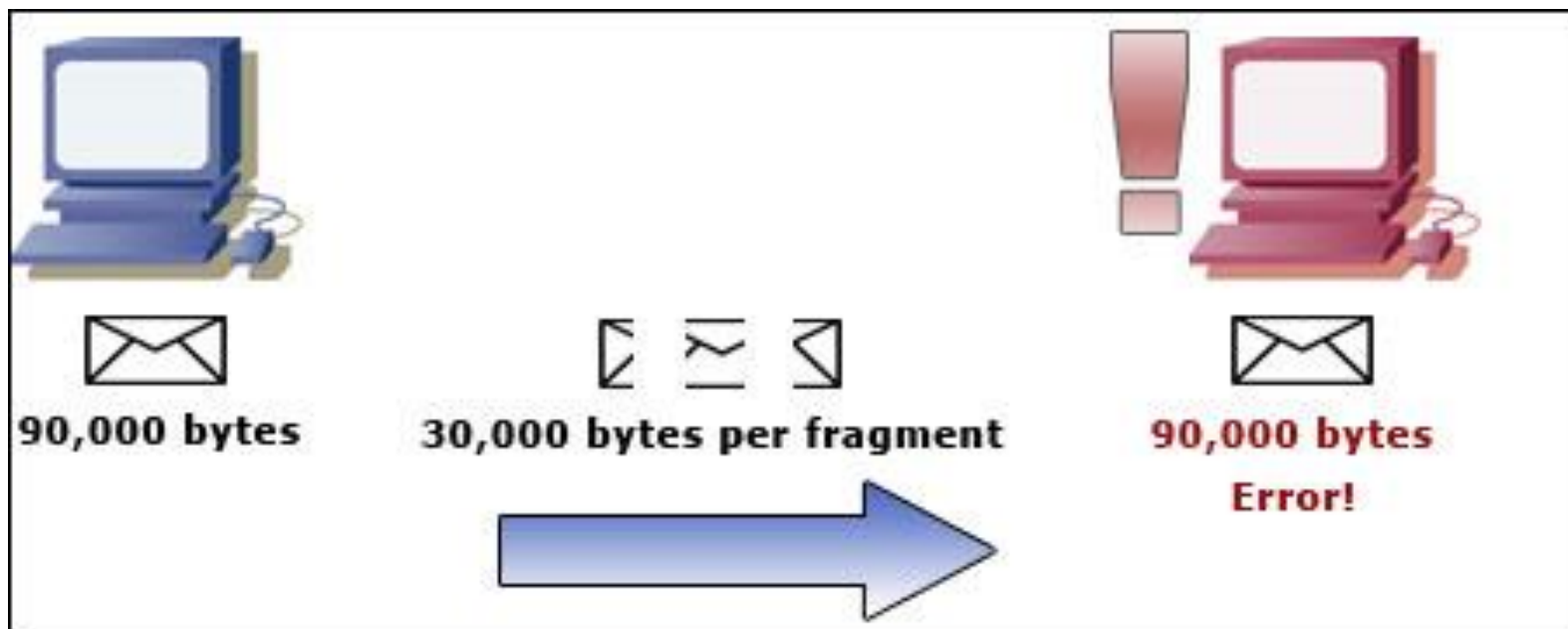
4.3 常用的黑客攻防技术

- ②Smurf攻击。利用TCP/IP中的定向广播特性，广播信息可以通过广播地址发送到整个网络中的所有主机，当某台主机使用广播地址发送一个ICMP包 echo请求包时，一些系统将回应ICMP echo回应包，同时也会收到许多响应包。



4.3 常用的黑客攻防技术

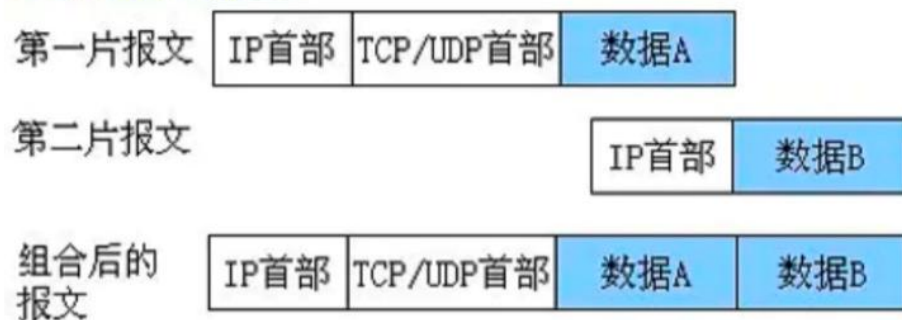
- ③Ping洪流攻击。也称**死亡之Ping**。利用早期操作系统处理ICMP协议数据包时存在的漏洞。一旦发送的ICMP数据包超过阈值（原64KB），操作系统就会对收到的数据报文向缓存区更新，当报文长度大于阈值时产生缓存溢出，结果导致TCP/IP堆栈崩溃，致使主机重启或死机。



4.3 常用的黑客攻防技术

- ④泪滴攻击。也称为**分片攻击**，是一种典型的利用TCP/IP漏洞进行的DoS, 因第一个实现攻击的程序名称Teardrop而得名。它向被攻击者发送多个分片IP包，导致目标操作系统收到含有重叠偏移的伪造分片数据包后，出现系统崩溃或重启。

正常分片IP报文

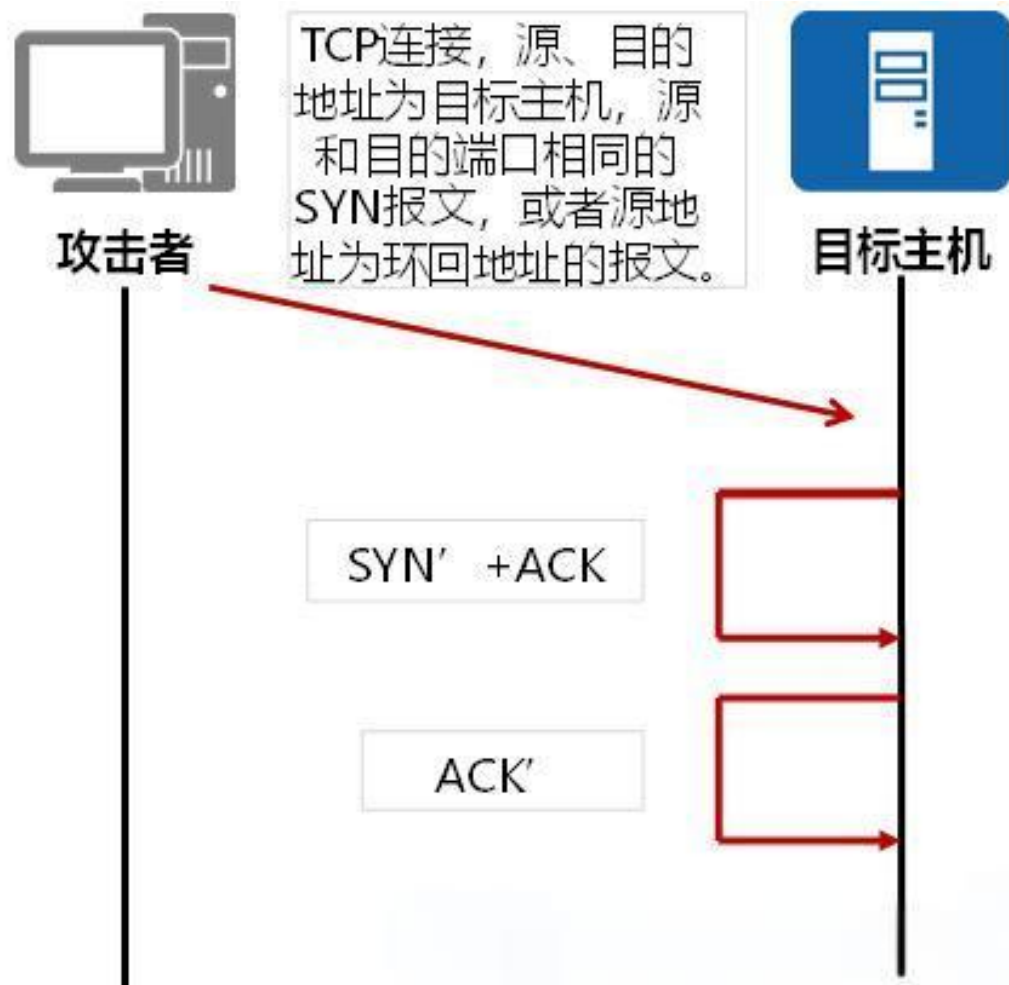


Teardrop攻击报文分片



4.3 常用的黑客攻防技术

- ⑤Land攻击。在攻击包中的源地址和目标地址都是攻击机IP的攻击，导致被攻击主机死循环，最终耗尽系统资源。



4.3 常用的黑客攻防技术

3) 拒绝服务攻击检测与防范。

检测DDos的主要方法：

根据异常情况分析和使用DDos检测工具。

防范DDoS主要策略包括：

- ①及时发现攻击网络系统的漏洞，尽快安装系统补丁程序。
- ②加强网络安全管理，经常检查系统物理环境，关闭非必要网络服务。
- ③利用网络安全设备（如防火墙）等强化网络安全性。
- ④强化网络安全访问控制和限制。同网络服务提供商ISP协调一致，帮助用户实现路由访问控制和对带宽总量的限制。
- ⑤发现正在遭受DDoS时，立即启动应急策略并追踪攻击包，及时联系应急组织和ISP，分析受影响系统，确定涉及的其他结点，阻断已知攻击结点的流量。
- ⑥对于潜在的DDoS应当及时清除或处理，以免留下后患



4.3 常用的黑客攻防技术

6. 网络欺骗的攻防

1) Web欺骗。指黑客篡改访问网页内容或将用户浏览网页URL篡改为指向黑客的服务器,向黑客服务器发机密信息等。

网络钓鱼指利用欺骗、伪造Web站点等诈骗方式,骗取用户名、账号及密码等,或假冒受害者欺诈金融交易等获利。

案例4-8

2022年期间,网络不法分子利用新型冠状病毒相关题材,冒充国家卫生健康委员会、疫情防控等相关部门,向我国部分单位和用户投放与新型肺炎疫情相关的钓鱼邮件,钓鱼邮件附带恶意链接与包含恶意代码的Office文档附件,利用仿冒页面实现对用户信息的收集,诱导用户执行恶意文档中的宏,向受害用户主机上植入木马程序,实现远程控制和信息窃取。

4.3 常用的黑客攻防技术

6.网络欺骗的攻防

2) 电子邮件欺骗。包括电子邮件攻击方式和防范方法:

①电子邮件欺骗方式。**电子邮件欺骗**是指攻击者佯称自己为系统管理员或领导等,给用户发送邮件要求用户修改密码或在表面正常的附件中加载病毒或其他木马程序。其目的隐藏身份并冒充他人骗取敏感信息。

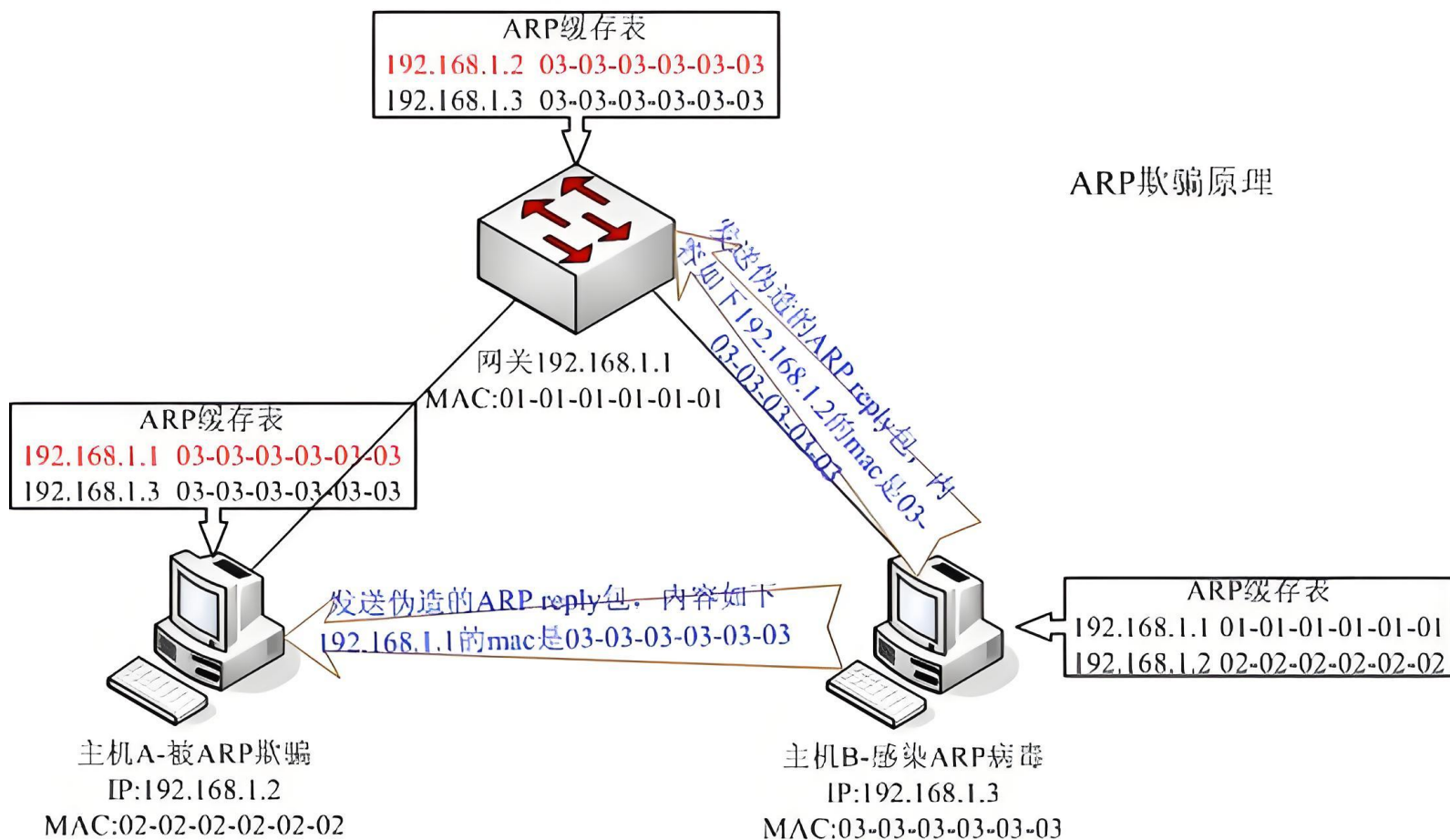
②防范电子邮件欺骗方法。设置邮件程序过滤功能等。

🔔注意: 黑客时常利用微信或QQ等冒充领导、亲属或好友,其欺骗攻击方式和防范方法同电子邮件欺骗完全类似,限于篇幅不再赘述。



4.3 常用的黑客攻防技术

6.网络欺骗的攻防



4.3 常用的黑客攻防技术

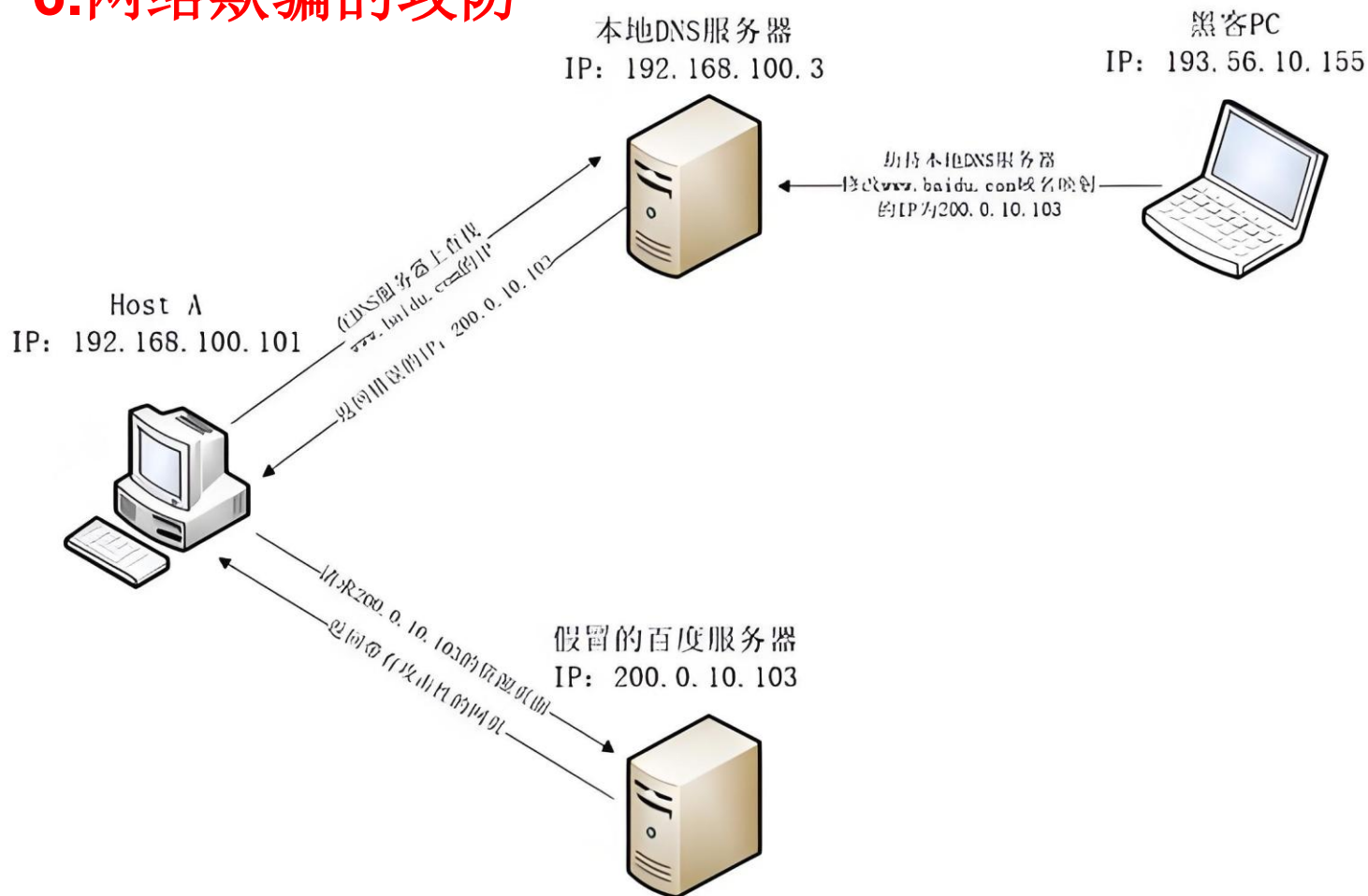
6.网络欺骗的攻防

IP欺骗攻击



4.3 常用的黑客攻防技术

6. 网络欺骗的攻防



DNS 欺骗攻击过程

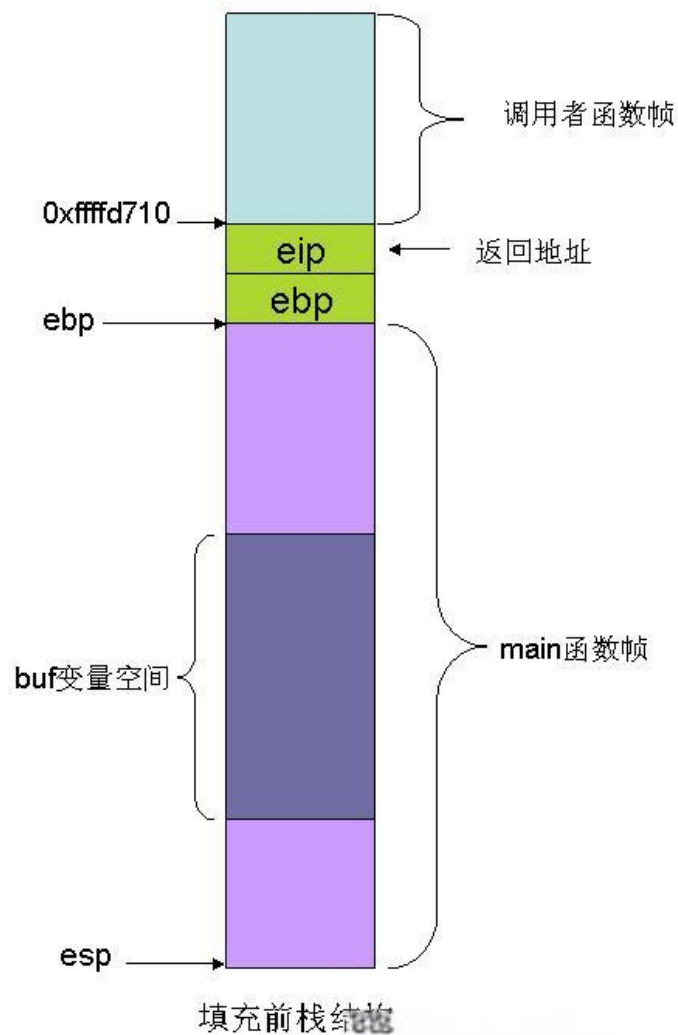
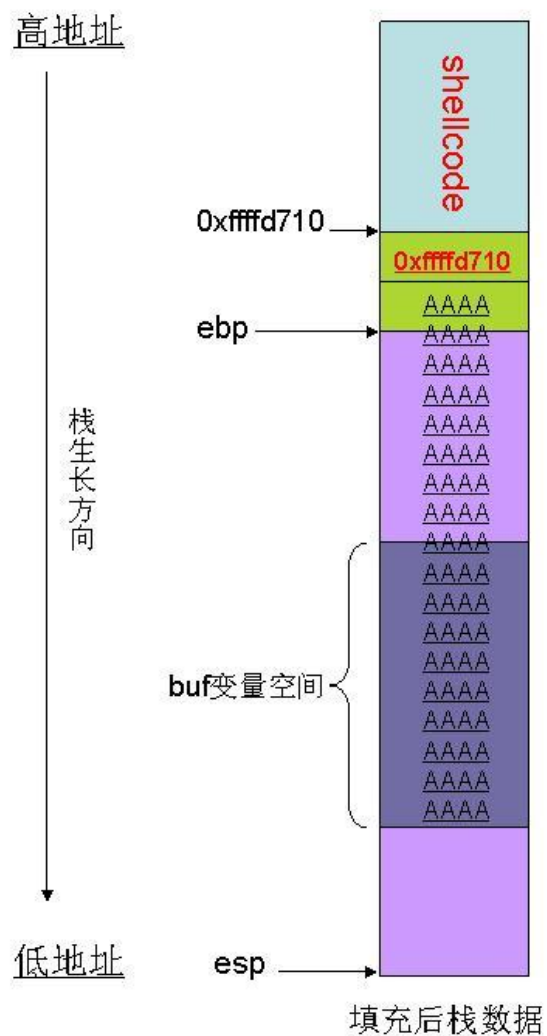
4.3 常用的黑客攻防技术

7.缓冲区溢出攻防

■ **缓冲区溢出攻击**指通过往程序的缓冲区写入超出其长度的内容造成溢出,破坏程序堆栈,使程序转而执行非预期指令,达到攻击目的。**缓冲区溢出**是一种在各种操作系统或应用软件中常见且危险的漏洞。可以被黑客用于改变程序的流控制或执行代码的任意片段,导致数据缓冲器和返回地址暂时关闭,或引起返回地址被重写,导致系统无法正常运行、关机/重启等。

■ **保护缓冲区免受溢出攻击主要方法**: 强化标准规范研发和检测,并利用在编译器中增加边界检查和堆栈保护的功能,使含有漏洞的程序和代码段无法通过编译。

4.3 常用的黑客攻防技术



4.3 常用的黑客攻防技术

8. 社会工程学的攻防

1) 社会工程学攻击。社会工程学攻击是一种利用社会工程学进行网络攻击的方式，通常利用用户的疏于安全防范和管理，骗取对方信任并获取机密信息。

2) 社会工程学攻击的防范。社会工程学攻击的本质是绕过人的判断力。最有效的防御不是技术，而是培养一种健康的怀疑文化——既保持协作效率，又对异常请求保持警觉。社会工程学攻击的形式多样，其成功率取决于人类在尝试谨慎分析不同情况时出现的盲点。防范的关键是加强管理、严加防范、完善法治和制度。

4.3 常用的黑客攻防技术

4.3.2 新式黑客攻防技术

https://www.cnii.com.cn/rmydb/202601/t20260130_711047.html

(1) APT攻击 (Advanced Persistent Threat)

高级持续性威胁APT的攻击方式，主要是利用先进（**高级**）攻击手段，对特定目标进行**长期**持续性网络攻击。APT攻击的原理相对于其他攻击形式更为高级和先进，其高级性主要体现在APT在发动攻击之前需要对攻击对象的业务流程和目标系统进行精确的收集。在此收集的过程中，此攻击会主动挖掘被攻击对象受信系统和应用程序的漏洞，利用这些漏洞组建攻击者所需的网络，并利用0day漏洞进行攻击。

APT攻击是由国家背景或大型组织支持的**长期、隐蔽、定向**网络攻击，具有三大核心特征：

特征	说明
高级性	使用0day漏洞、定制恶意软件、高级逃逸技术，能绕过传统防火墙、杀毒软件等基于特征的防御
持续性	在目标网络中长期潜伏（数月甚至数年），持续收集情报、扩展权限
威胁性	明确针对高价值目标（政府、关键基础设施、军工、高科技企业），意图窃取核心机密或破坏关键系统

4.3 常用的黑客攻防技术

4.3.2 新式黑客攻防技术

组织代号	归属/背景	主要目标	典型手法
APT-C-40 (NSA)	美国	我国关键基础设施、高科技企业	利用0day漏洞、学术机构作掩护
APT-C-00 (海莲花)	越南	我国国际关系、海事研究、经贸领域	钓鱼邮件、PHP-CGI漏洞利用、Python后门
APT-C-36 (盲眼鹰)	南美	哥伦比亚、委内瑞拉等政府司法系统	恶意URL文件、云盘投递、Hi jackloader加载器
Lazarus	朝鲜	全球金融机构、加密货币	供应链攻击、品牌劫持、域名抢注
银狐 (Silver Fox)	未知	Windows环境	滥用签名驱动程序(amsdk.sys)绕过EDR/杀毒软件

4.3 常用的黑客攻防技术

4.3.2 新式黑客攻防技术

- 常见攻击链
- 初始入侵：鱼叉式钓鱼邮件、水坑攻击、供应链投毒、VPN漏洞利用
- 权限提升：0day漏洞、DLL侧载、驱动程序滥用
- 持久化：内存驻留（无文件攻击）、计划任务、WMI事件订阅
- 横向移动：Pass-the-Hash、远程桌面、SMB协议滥用
- 数据窃取：加密压缩、分阶段外传、C2隐蔽通信

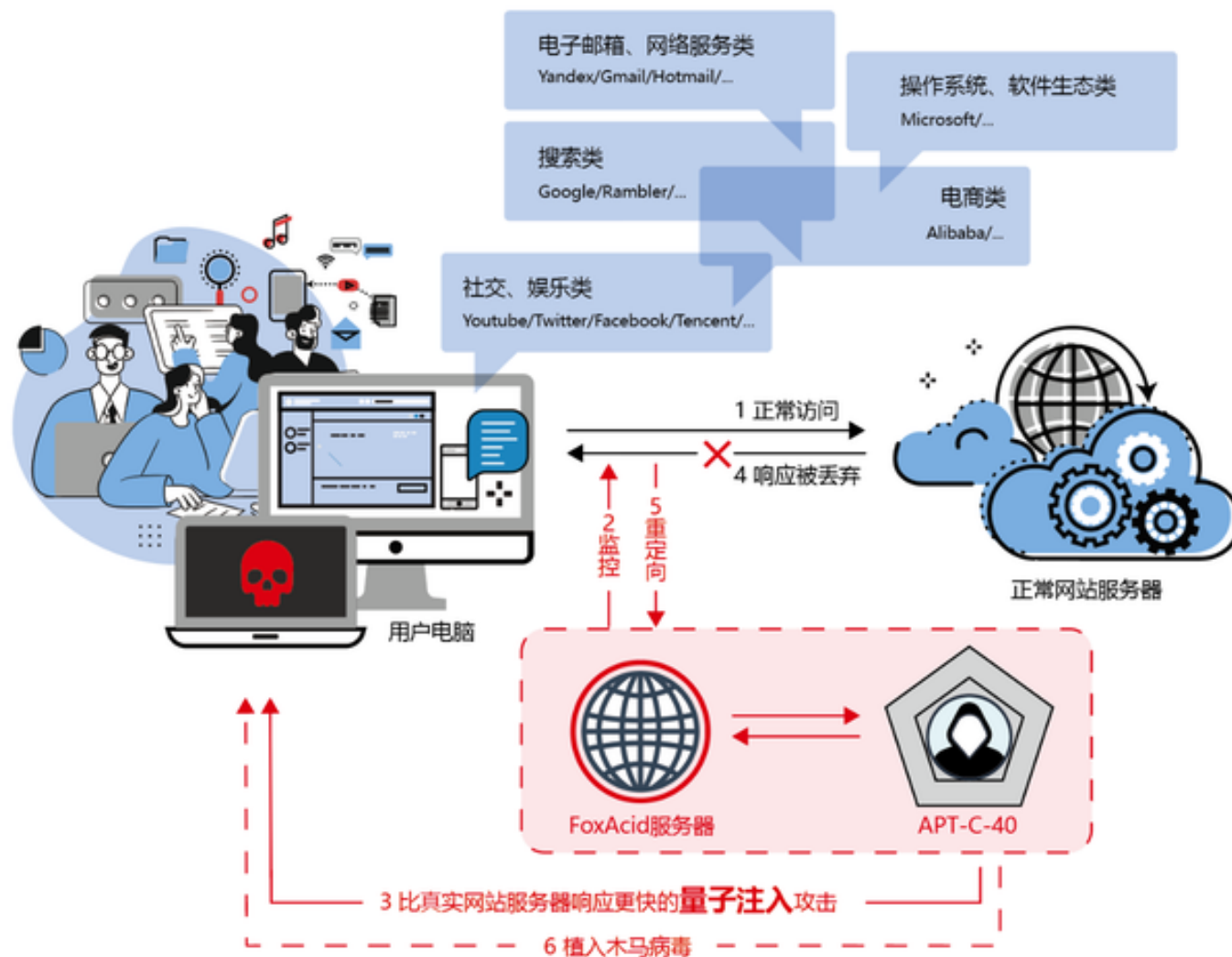
4.3 常用的黑客攻防技术

4.3.2 新式黑客攻防技术

案例4-10

美国利用量子攻击系统进行高级持续性攻击**APT**。2022年3月360公司报告：美国利用量子**QUANTUM**攻击系统进行**APT**攻击，结合实证案例对应用场景和攻击实施过程进行技术分析，再次印证美国针对全球互联网用户实施**大规模无差别网络攻击**的特征：网络武器攻击已经工程化自动化，为实施并制胜网络战充分利用一切先进技术和网络资源，美国网络攻击属于无差别攻击目标是全球范围甚至包括盟友，美国的网络战战略已经不仅限于网络窃密。

4.3 常用的黑客攻防技术



4.3 常用的黑客攻防技术

（2）硬件攻击（硬件供应链）攻防

黑客（或集团）对关键的设备或CPU、存储器或数据线等部件植入间谍插件或篡改，便于远程控制操作或窃取机密信息的目的，或便于逃避防火墙及杀毒软件、安全辅助工具的追踪与查杀，导致部分设备不连网也能被攻击。为防范硬件攻击，采用正规设备并请公安等权威机构进行安全检测和管理，强化相关安全防范策略。

（3）虚拟机攻防

黑客可用虚拟机对目标进行攻击，甚至利用虚拟网进行隐藏式攻击。黑客利用虚拟机相关知识，实施跨虚拟机硬件攻击、虚拟网络攻击、虚拟系统攻击、恶意软件攻击、隐藏式代理攻击等。黑客可用虚拟机作案，及时关闭虚拟机系统并删除相关文件等逃脱追究。为防范虚拟机攻击，先做好系统加固、隔离和预防，并检测系统异常及痕迹，保留证据并报警。

（4）无线隐秘攻防

黑客利用无线网络或通信技术窃听或截获用户机密信息，并实施有效攻击。黑客还可以通过无线通讯技术接入网络的核心部分，实施各种攻击。为防范无线隐秘攻击，需要加强无线网络和通信安全机制，采取系统和数据加密等措施。

在黑客攻击技术中，（ ）是黑客发现获得主机信息的一种最佳途径。

- ☒ A 端口扫描
- ☐ B 缓冲区溢出
- ☐ C 网络监听
- ☐ D 密码破解

提交

() 利用以太网特点，将设备网卡设置为“混杂模式”，从而能够接收到整个以太网的网络数据信息。

- ☐ A 缓冲区溢出攻击
- ☐ B 木马程序
- ☒ C 嗅探程序
- ☐ D 拒绝服务攻击

提交

字典攻击被用于（ ）。

- ☐ A 用户欺骗
- ☐ B 远程登录
- ☐ C 网络嗅探
- ☒ D 破解密码

提交

4.4 网络攻击的防范措施

4.4.1 网络攻击的防范策略

在主观上重视，客观上积极采取措施。制定规章制度和管理制度，普及网络安全教育，使用户需要掌握网络安全知识和有关的安全策略。在管理上应当明确安全对象，建立强有力的安全保障体系，按照安全等级保护条例对网络实施保护与监督。认真制定有针对性的防攻措施，采用科学的方法和行之有效的技术手段，有的放矢，在网络中层层设防，使每一层都成为一道关卡，从而让攻击者无隙可钻、无计可使。在技术上要注重研发新方法，同时还必须做到未雨绸缪，预防为主，将重要的数据备份（如系统日志）、关闭不用的主机服务端口、终止可疑进程和避免使用危险进程、查询防火墙日志详细记录、修改防火墙安全策略等。

案例4-11

设置代理服务器实际应用。通常，用户点击网络进行资源访问和浏览等实际操作的应用，都是通过外部网络向内部网络申请网络服务，常由代理服务器接受申请，然后根据服务类型、内容、被服务的对象、服务者申请的时间、申请者的域名范围IP地址等决定是否接受服务，如果接受就向内部网络转发其请求。

4.4 网络攻击的防范措施

4.4.2 网络攻击的防范措施

- 1) 加强网络安全防范法律法规等宣传和教育，提高安全防范意识。
- 2) 加固网络系统，及时下载、安装系统补丁程序。
- 3) 尽量避免从Internet下载不知名的软件、游戏程序。
- 4) 不要打开不明邮件及文件，不要运行陌生人的程序。
- 5) 不运行黑客程序，运行时会发送用户的个人信息。
- 6) 若发现不明广告，先看源地址及代码，可能是骗取密码的陷阱。
- 7) 设置安全密码。用字母数字混排，常用的密码设置不同，常更换。
- 8) 使用防病毒/黑客等防火墙软件，以阻挡外部网络侵入。
- 9) 隐藏自己的IP地址。
- 10) 做好端口防范。安装监视程序，关闭不用端口。
- 11) 加强IE浏览器对网页的安全防护。
- 12) 上网前备份注册表。
- 13) 加强网络安全管理。



讨论思考：

- (1) 为什么要防范黑客攻击？如何防范黑客攻击？
- (2) 简述网络安全防范攻击的基本措施有哪些？
- (3) 说出几种通过对IE属性的设置来提高IE访问网页的安全性的具体措施？

4.5 入侵检测与防御系统概述



4.5.1 入侵检测系统的概念

1. 入侵和入侵检测的概念

入侵是指非授权进入网络系统进行访问、操作、影响和破坏的任何行为。**主要入侵行为**包括：非授权访问或越权访问系统资源、搭线窃听或篡改、破坏网络信息等。实施入侵行为的人通常称为**入侵者**或**攻击者**。

入侵检测（Intrusion Detection, ID）是指**通过对**行为、安全日志、审计数据或其它网络上**可获得的信息**进行操作，**检测到对**系统的**闯入或企图**的过程。它是继防火墙后的第二道安全栅门。

案例4-12

美国中情局下属组织窃取中国高科技产业的情报。中国外交发言人赵立坚曾表示，美国中情局下属组织通过各种木马软件和伪装性极强的病毒邮件等窃取中国高科技产业的情报，中国国家互联网应急中心数据表明**2020年**,中国境内就有超过**531万台**主机因境外恶意攻击而被控制,中国已成为世界网络攻击重要对象,并遭受重大损失。美国不仅攻击中国关键基础设施和伊朗核设施等,还监控窃听多国盟友。

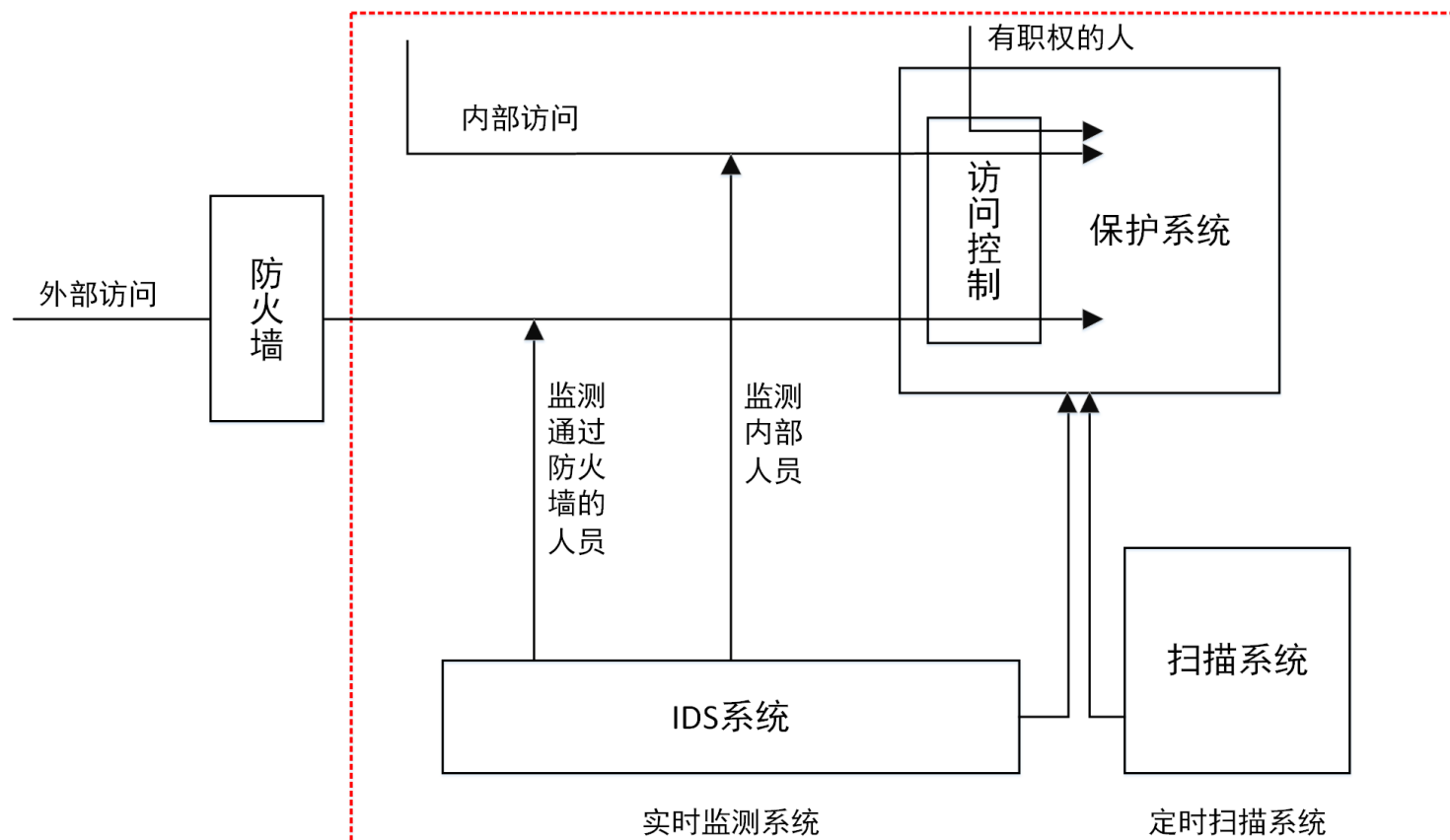
4.5 入侵检测与防御系统概述



4.5.1 入侵检测系统的概念

■ 1. 入侵和入侵检测的概念

入侵检测是继防火墙后的第二道安全栅门。



4.5 入侵检测与防御系统概述

2. 入侵检测系统的概念及原理

入侵检测系统(Intrusion Detection System,IDS),是可对入侵**自动进行检测、监控和分析**的软件与硬件的**组合系统**,是一种**自动监测**信息系统内外入侵的安全**系统**。IDS**通过**从计算机网络或系统中的若干关键点**收集**信息,并对其**进行分析**,从中**发现**网络或系统中**违反**安全策略的**行为和遭到袭击的迹象的一种安全技术**。

1) 入侵检测系统产生与发展。

20世纪80年代初,美国的詹姆斯安德森首次阐述了入侵检测的概念,提出了通过特征分析利用审计跟踪数据监视入侵活动的思想。

1990年,加州大学分校研发出网络安全监听(NSM)系统,并率先直接将网络流量作为审计数据来源,可在不将审计数据转换成统一格式的情况下监控异常主机。

IDS发展过程中出现了两大阵营:**基于主机的入侵检测系统**和**基于网络的入侵检测系统**。之后将基于主机和基于网络的检测方法集成在一起,开展了对**分布式入侵检测系统**的研究,这是入侵检测系统发展的一个里程碑

4.5 入侵检测与防御系统概述

2. 入侵检测系统的概念及原理

2) Denning模型。1986年乔治敦大学研究出了一个实时入侵检测系统模型——**入侵检测专家系统IDES**，也称Denning模型。

Denning模型基于的假设：攻击者使用系统的模式不同于正常用户的模式，通过监控系统跟踪记录，可以识别攻击者异常使用系统的模式，从而**检测出攻击者违反系统安全性的特征**。此模型独立于特定的系统平台、应用环境、系统弱点和入侵类型，为构建入侵检测系统提供了一个通用的原理框架。

该模型的结构包括：主体、审计记录和六元组<活动，目标，异常条件，资源使用状况，时间戳>

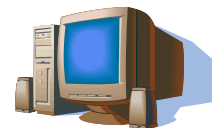
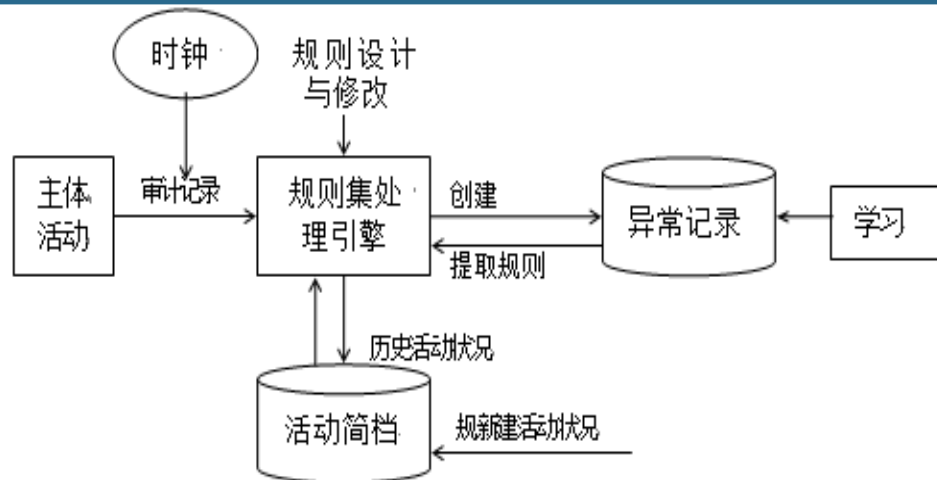


图4-6 入侵检测系统原理

4.5 入侵检测与防御系统概述

例子1：登录时间异常检测

维度	正常用户模式	攻击者异常模式	检测机制
时间	工作日 9:00-18:00	凌晨 3:00 登录	时间阈值告警
频率	每天1-2次	短时间内50次尝试	频率统计异常
来源	固定IP段	境外IP/新地理位置	地理位置模型

场景：某员工账户平时只在工作时间从北京办公室登录，某天凌晨3点从乌克兰IP多次尝试登录 → 触发异常告警。



4.5 入侵检测与防御系统概述

例子2：文件访问模式异常

- 正常用户轮廓（基于历史数据）：
 - - 常访问目录： /home/username/docs, /projects/team_a/
 - - 文件类型： .doc, .xlsx, .ppt（办公文档）
 - - 访问频率： 每小时10-20个文件
 - - 操作类型： 读(90%)、写(10%)
- 攻击者异常行为：
 - - 首次访问 /etc/shadow, /var/log/auth.log（系统敏感文件）
 - - 大量读取 .zip, .sql 文件（数据打包行为）
 - - 短时间内访问500+文件（爬虫式遍历）
 - - 操作： 复制到 /tmp/backup（异常写入路径）



4.5 入侵检测与防御系统概述

例子2：文件访问模式异常

- 正常用户轮廓（基于历史数据）：
 - - 常访问目录：/home/username/docs, /projects/team_a/
 - - 文件类型：.doc, .xlsx, .ppt（办公文档）
 - - 访问频率：每小时10-20个文件
 - - 操作类型：读(90%)、写(10%)
- 攻击者异常行为：
 - - 首次访问 /etc/shadow, /var/log/auth.log（系统敏感文件）
 - - 大量读取 .zip, .sql 文件（数据打包行为）
 - - 短时间内访问500+文件（爬虫式遍历）
 - - 操作：复制到 /tmp/backup（异常写入路径）

检测：偏离度 = (新文件类型熵 + 路径异常度 + 频率偏离度) > 阈值 → 告警

4.5 入侵检测与防御系统概述

例子3：网络流量行为异常

指标	正常基线	攻击特征
连接数	50个/小时	1000个/小时（端口扫描）
流量方向	出站>入站（浏览为主）	入站>>出站（被植入木马，接收指令）
协议分布	HTTP 80%，HTTPS 15%	SSH/FTP突增
数据包大小	均值500B	大量小包（SYN Flood）

4.5 入侵检测与防御系统概述

4.5.2 入侵检测系统的功能及分类

■ 1. IDS基本结构

IDS主要由事件产生器、事件分析器、事件数据库、响应单元等构成。

- 事件产生器：用于特征信息采集，并将收集到的信息（数据）转换为事件，向系统的其他部分提供并分析处理。收集的信息包括：系统或网络的日志文件、网络流量、系统目录和文件的异常变化、程序执行中的异常行为等。
- 事件分析器：运用特征匹配或异常检测技术识别事件中的入侵行为
 - 分析方法：
 - 1) 模式匹配：将采集的事件与已知攻击特征库进行比对，识别特定入侵行为；
 - 2) 统计分析：建立正常行为基线，通过偏离程度检测异常活动；
 - 3) 完整性分析：监控关键系统文件或对象的属性变化，发现非授权篡改
- 事件数据库：存储原始事件、分析结果及历史数据用于审计和取证
- 响应单元：根据分析结果执行告警通知或主动阻断等防御措施检测

4.5 入侵检测与防御系统概述

4.5.2 入侵检测系统的功能及分类

■ 2. IDS的主要功能

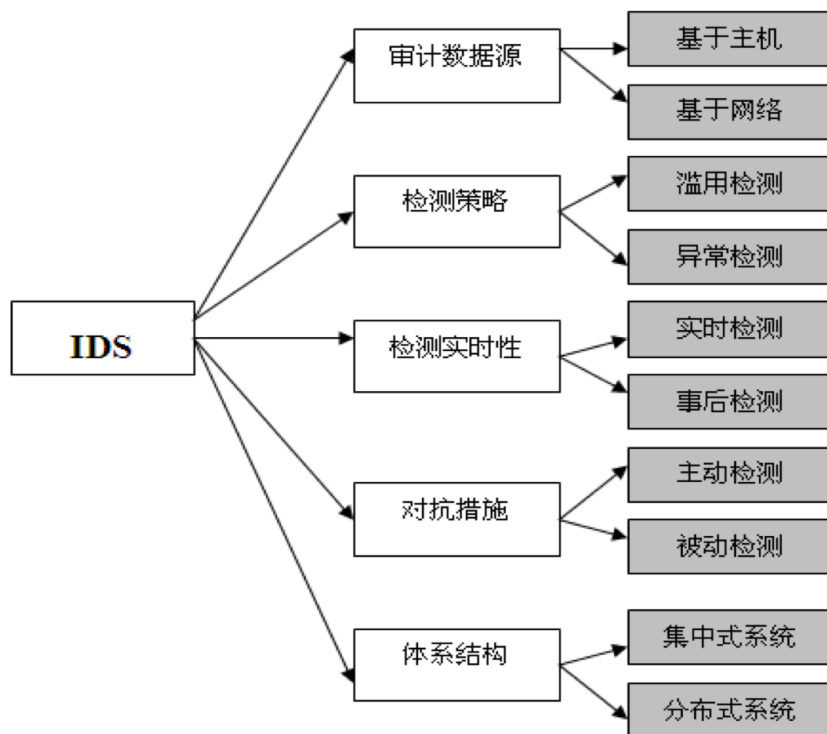
- 1) 对网络流量的跟踪与分析。跟踪用户从登陆网络到退出的所有操作活动，实时监测并分析用户在系统中的活动状态
- 2) 对已知攻击特征的识别。包括识别攻击特征、向控制台报警、为防御提供依据。
- 3) 对异常行为的分析、统计与响应。包括分析系统的异常行为模式、统计异常行为，并对异常行为做出响应。
- 4) 特征库的在线升级。包括提供在线升级，实时更新入侵特征库，不断提高IDS的入侵检测能力。
- 5) 数据文件完整性检验。包括通过检查关键数据文件的完整性，识别并报告数据文件的改动情况。
- 6) 自定义特征的响应。包括定制实施相应策略；根据用户定义，经过系统过滤，对警报事件及时响应。
- 7) 系统漏洞预报警。主要对尚未发现的系统漏洞特征进行与报警。

4.5 入侵检测与防御系统概述

4.5.2 入侵检测系统的功能及分类

■ 3. IDS的主要分类

- 1) 按照**体系结构**分为：**集中式和分布式**。
- 2) 按照**工作方式**分为：**离线检测和在线检测**。
- 3) 按照**所用技术**分为：**特征检测和异常检测**。
- 4) 按照**检测对象** (数据来源) 分：**基于主机、基于网络和分布式(混合型)**。



4.5 入侵检测与防御系统概述

4.5.3 常用的入侵检测方法

1. 特征检测方法

特征检测指对已知的**攻击或入侵特征**作出确定性的**表示**，形成相应的事件模式的检测方式。当被检测事件与已知入侵事件**模式特征匹配**时**报警**。同计算机病毒的检测方式类似。优点：应用广且**误报少**；缺点：只能发现已知攻击，**对未知攻击无法检测**。（？）

2. 异常检测方法

异常检测 (Anomaly detection) 的**假设（认为）**是入侵者**活动异常**于正常主体的活动，以此建立主体正常活动的“活动库”。当前用户活动状况与“活动库”进行比对，当超出统计模型时，认为该活动可能是“入侵”行为。其检测难题在于建立“活动库”和设计统计模型。常用的**入侵检测5种统计模型**：

- 1) 操作模型；
- 2) 统计方差；
- 3) 多元模型；
- 4) 马尔柯夫过程模型；
- 5) 时间序列分析。

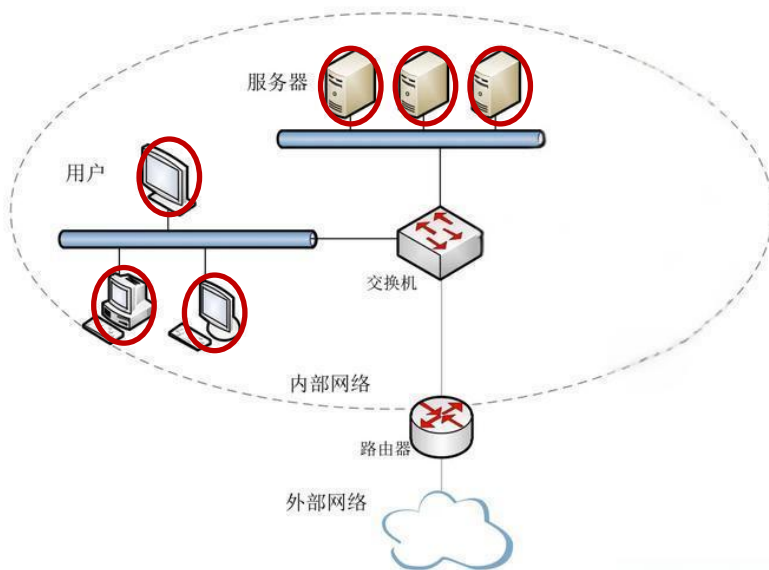
4.5 入侵检测与防御系统概述

4.5.4 入侵检测系统与防御系统

1. 入侵检测系统概述

(1) 基于主机的入侵检测系统（HIDS）

以主机系统日志、应用程序日志等作为数据源，或通过监督系统调用等手段，收集信息进行分析的检测系统。HIDS通常用于保护主机及其所在系统，经常部署在被监测的系统上，监测系统正在运行的进程合法性，可以被用于多种平台。



4.5 入侵检测与防御系统概述

4.5.4 入侵检测系统与防御系统

1. 入侵检测系统概述



(1) 基于主机的入侵检测系统 (HIDS)

优点：对检测分析“可能的攻击行为”非常有效。有时除了检测入侵者试图执行一些异常“攻击操作”之外，还能分辨出入侵者做的事务、运行的程序、打开的文件、执行的系统调用。与NIDS相比可提供更详尽的主机信息，漏报、误报率低，系统的复杂性小。

弱点：HIDS安装在需要保护的设备上，会降低应用系统的效率，也会带来一些额外安全问题，如将原来未授权安全管理人员访问的服务器变得可以访问等。依赖于服务器固有的日志与监视能力，若服务器没有配置日志功能，则必须重新配置，这将影响业务应用系统的性能。全面部署HIDS代价较大，实际中很难将所有的主机用于HIDS保护，未安装HIDS的主机将成为保护盲点，入侵者可利用这些主机对目标进行攻击。此外，HIDS除了检测自身主机以外，无法检测网络情况，对入侵行为的分析工作量将随着主机数目的增加而增加。

4.5 入侵检测与防御系统概述

(2) 基于网络的入侵检测系统 (NIDS)

NIDS又称**嗅探器**,通过**在共享网段上对通信数据的侦听进行检测**,并**分析可疑现象**(将NIDS**放置在较重要的网段**,及时**监视网段中的各种数据包**,NIDS**输入数据**源于**网络信息流**)。该类系统通常**被动地在网络上监听整个网络上的信息流**,通过**捕获网络数据包进行分析**,检测该网段上发生的**入侵行为**,如图4-8示。

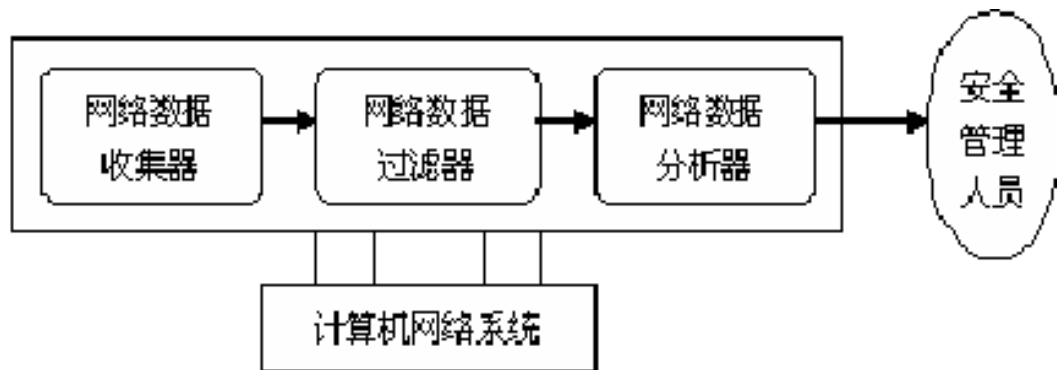
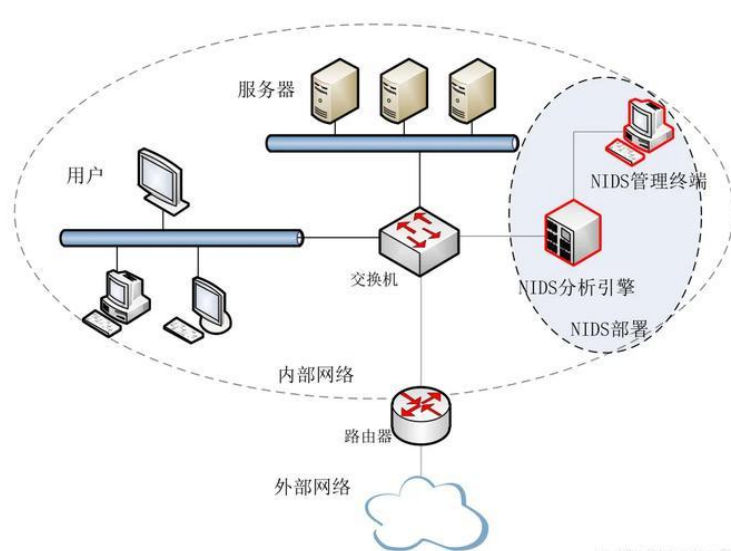


图 4-8 基于网络的入侵检测过程

4.5 入侵检测与防御系统概述

(2) 基于网络的入侵检测系统 (NIDS)

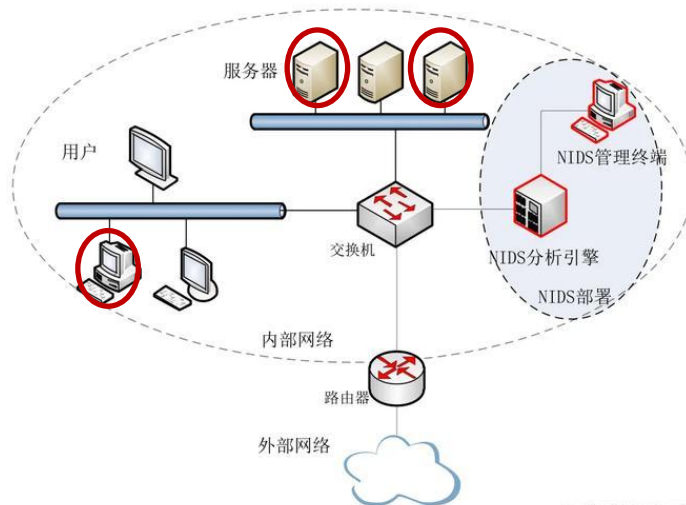
优点： NIDS能够检测来自网络的攻击及非授权访问。它不需要改变服务器或主机的配置，不会影响这些服务器或主机的CPU、I/O、与磁盘等资源的使用，不会影响业务系统的性能。NIDS不像路由器、防火墙等关键设备那样工作，不会成为系统中的关键路径。NIDS发生故障不会影响正常业务的运行，因此部署一个NIDS的风险比HIDS的风险小很多。部署NIDS非常方便，只需将定制的设备接上电源，进行很少的一些配置并将其连到网络上即可。NIDS近年来已经有向专用设备发展的趋势。

弱点： NIDS只检查起直接连接网段的通信，不能检测不同网段的网络包，在以太网的环境中会出现检测范围的局限，安装多台NIDS会使部署整个系统的成本增大。NIDS通常采用特征检测的方法提高性能，可以检测出一些普通攻击，而很难检测那些复杂的需要大量计算和分析时间的攻击。NIDS可能会将大量的数据传回分析系统，而且NIDS中的传感器协同工作能力较弱，处理加密会话过程较困难。

4.5 入侵检测与防御系统概述

(3) 分布式入侵检测系统

分布式入侵检测系统DIDS是将基于主机和基于网络的检测方法集成在一起的**混合型入侵检测系统**。系统通常由多个部件组成，分布在指定网络或主机的部位，完成相应的检查功能，分别进行数据采集、数据分析等，最后通过中心的控制部件进行数据汇总、分析、产生入侵报警等。DIDS不仅可以检测到针对单独主机的入侵，同时也可以检测到针对整个网络上的攻击事件。



4.5 入侵检测与防御系统概述

4.5.4 入侵检测及防御系统

■ 2. 入侵防御系统概述

■ 1) 入侵防御系统IPS的概念

IPS指监视网络或其设备的网络信息传输行为，及时中断、调整或隔离异常或具有破坏性的网络信息传输行为的系统。如同IDS类似，专门深入网路数据内部查找攻击代码特征，过滤有害数据流，丢弃有害数据包，并进行记载，以便事后分析。更重要的是，大多数IPS可结合应用程序或网络传输中的异常情况，辅助识别入侵和攻击。IPS虽然也考虑已知病毒特征，但是并不只依赖于已知病毒特征，通常作为防火墙和防病毒软件的补充。在必要时，还可以为追踪攻击者的刑事责任提供有效的法律依据。

4.5 入侵检测与防御系统概述

4.5.4 入侵检测及防御系统

■ 2. 入侵防御系统概述

2) 入侵防御系统的种类

按其用途可以划分为3种类型：**基于主机**的入侵防御系统、**基于网络**的入侵防御系统、**分布式**入侵防御系统。

3) 入侵防御系统的功能

一是**具有异常检测防御功能**，利用已知正常数据和数据之间关系的常见模式，对比识别异常行为。主要结合**协议异常、传输异常和特征异常**进行检测，同时对通过网关或防火墙进入网络内部的危险代码或数据包进行有效阻断；

二是在遇到**动态代码**时，先观察其行为动向，如果发现异常情况，则**停止传输并禁止执行**；

三是**具有在核心基础上的防护机制**，用户程序通过系统指令共享资源，如存储区、I/O设备等，IPS可以截获危险的系统请求；

四是可以**对重要文件及数据资源进行保护**。

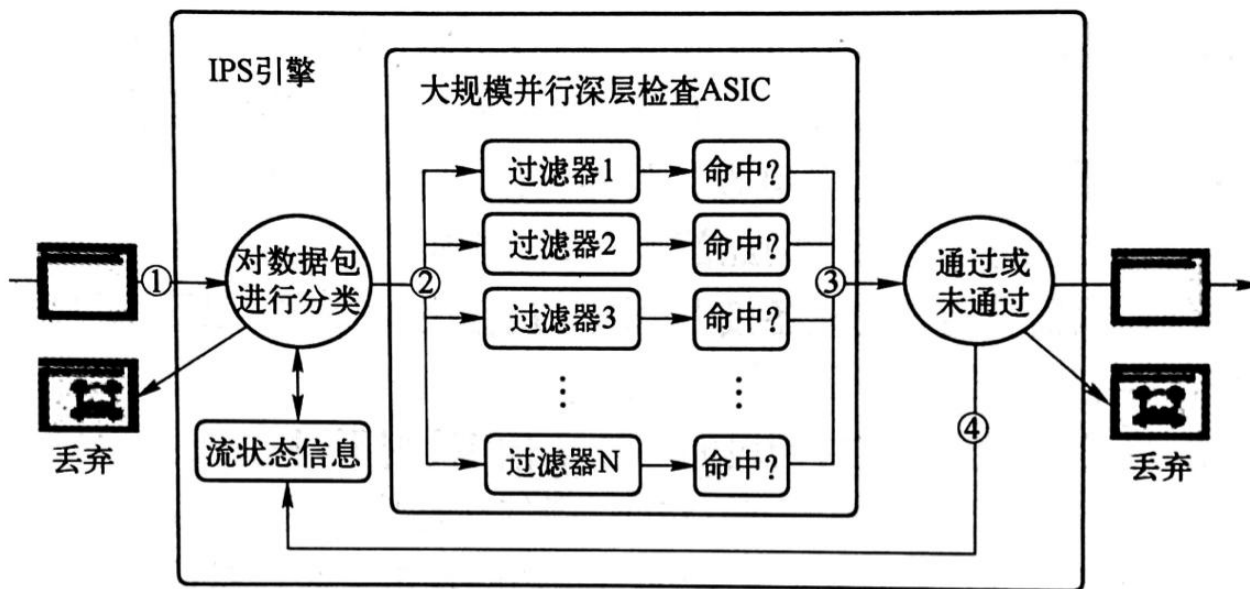
4.5 入侵检测与防御系统概述

4.5.4 入侵检测及防御系统

2. 入侵防御系统概述

4) IPS工作原理/流程

IPS实现**实时检查**和**阻止入侵**的原理如图所示。



- ① 根据报头和流信息，每个数据包都会被分类。
- ② 根据数据包的分类，相关的过滤器将被用于检查数据包的流状态信息。
- ③ 所有相关过滤器都是并行使用的，如果任何数据包符合匹配要求，则该数据包将被标为命中。
- ④ 被标为命中的数据包将被丢弃，与之相关的流状态信息也会更新。指示系统丢弃该流中删除的所有内容。

4.5 入侵检测与防御系统概述

案例4-10

H3C SecBlade IPS入侵防御系统. 是一款高性能入侵防御系统, 可应用于多个系列交换机和路由器, 集成入侵检测及防御、病毒过滤和带宽管理等功能, 是业界综合防护技术最领先的入侵防御/检测系统. 通过深达7层的分析与检测, 实时阻断网络流量中隐藏的病毒、蠕虫、木马、间谍软件、网页篡改等攻击和恶意行为, 并实现对网络基础设施、网络应用和性能的全面保护。

SecBlade IPS模块与基础网络设备融合, 具有即插即用、扩展性强**特点**. **IPS部署交换机**应用如图4-9, **IPS部署路由器**应用, 如图4-10。

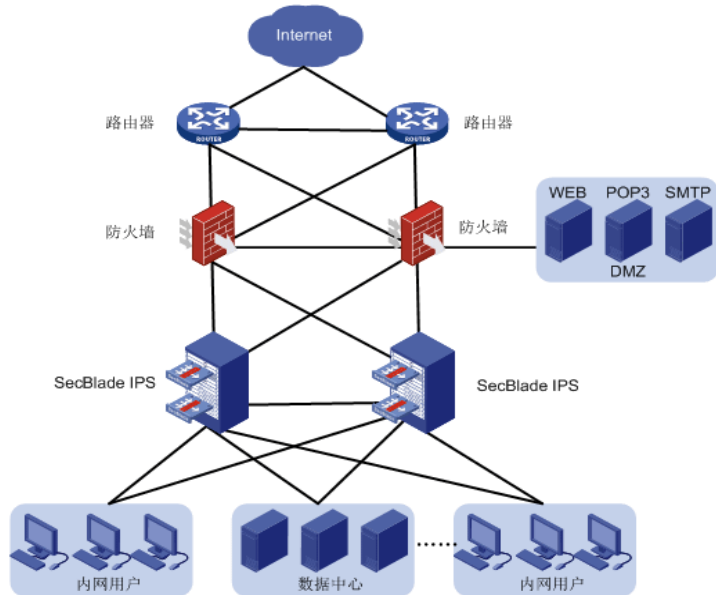


图4-9 IPS部署交换机的应用

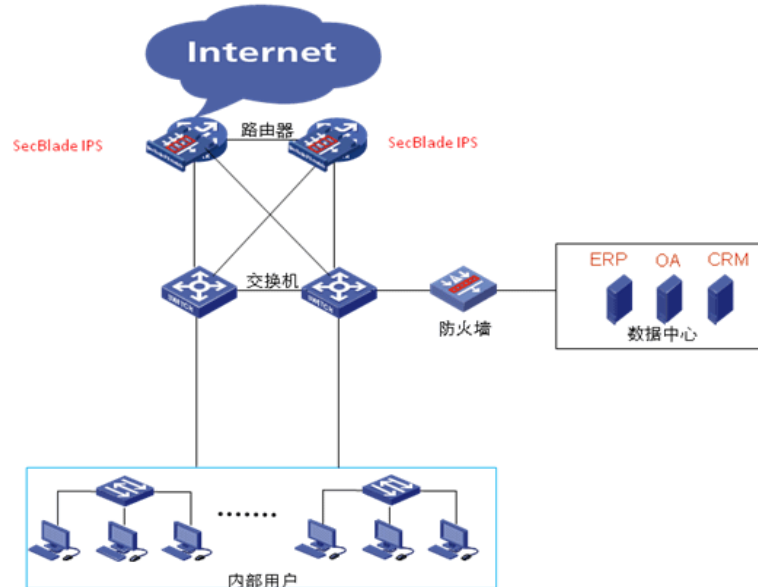


图4-10 IPS部署路由器的应用

4.5 入侵检测与防御系统概述

防火墙如大厦门锁，
IDS如大厦监视系统
IPS如大厦保安（门卫）

3. 防火墙、IDS与IPS的区别

防火墙是实施访问控制策略的系统，对流经网络流量进行检查，拦截不符合安全策略的数据包。

IDS的核心价值在于通过对全网信息分析，了解系统安全状况，指导信息系统安全建设目标及安全策略的确立和调整。通过安全策略的实施，阻击黑客行为；**IDS需部署在网络内部**，监控范围可覆盖整个子网，包括来自外部的数据以及内部终端之间传输的数据。**防火墙**部署在网络边界，抵御外部的入侵，对内部攻击行为无能为力。

IDS通过监视网络或系统资源，**寻找**违反安全策略的行为或攻击迹象，并**发出报警**。**传统的防火墙**旨在拒绝那些明显可疑的网络流量，但仍然允许某些流量通过，因此防火墙对于很多入侵攻击仍无计可施。绝大多数IDS都是被动的。而**IPS**则倾向于**提供主动防护**，其设计宗旨是预先对入侵活动和攻击性网络流量进行拦截，避免其造成损失，而不是简单地在恶意流量传送时或传送后才发出警报。

4.5 入侵检测与防御系统概述

对比维度	IDS	IPS
核心功能	检测 + 告警	检测 + 阻断
响应方式	被动（记录日志、发送警报）	主动（丢弃数据包、重置连接、阻断IP）
部署方式	旁路监听（Tap/SPAN端口）	串联部署（Inline），位于流量必经路径
对业务影响	无延迟，不影响网络性能	可能引入微秒级延迟，存在误阻断风险
误报代价	较低（仅告警）	较高（可能阻断正常业务）
防护时效	事后追溯	实时防护

4.5 入侵检测与防御系统概述

*4.5.5 入侵检测及防御技术的发展态势

1. 入侵检测及防御技术发展态势

三个发展方向：

1) 分布式入侵检测与防御：第一层含义，即针对分布式网络攻击的检测与防御方法；第二层含义即使用分布式的方法来检测与防御分布式的攻击，其中的关键技术为检测信息的协同处理与入侵攻击的全局信息的提取。

2) 智能化入侵检测及防御：使用智能化的方法与手段进行入侵检测与防御。

3) 全面的安全防御方案：



2. 统一威胁管理

统一威胁管理 (Unified Threat Management, UTM), 2004年9月, 全球著名市场咨询顾问机构—IDC(国际数据公司), 首度提出此概念, 将防病毒、入侵检测和防火墙安全设备划归统一威胁管理。

4.5 入侵检测与防御系统概述

*4.5.5 入侵检测及防御技术的发展态势

2. 统一威胁管理

功能模块	说明
网络防火墙	基于状态检测的包过滤，控制网络流量进出
入侵检测/防御（IDS/IPS）	实时监测并阻断恶意攻击行为
防病毒（AV）	检测和清除恶意软件、病毒
VPN 支持	提供安全的远程访问和站点互联
内容过滤	控制网页访问、应用使用
反垃圾邮件	过滤恶意邮件和钓鱼攻击
应用控制	基于应用层识别进行精细管控

4.5 入侵检测与防御系统概述

4.5.5 入侵检测及防御技术的发展趋势

(1) UTM重要特点

- 1) 建一个更高、更强、更可靠的墙,除了传统的访问控制之外,防火墙还应该对防垃圾邮件、拒绝服务、黑客攻击等这样的一些外部的威胁起到综合检测网络全协议层防御;
- 2) 用高检测技术降低误报;
- 3) 用高可靠、高性能的硬件平台支撑。

UTM优点:整合使成本降低、信息安全工作强度降低、技术复杂度降低。

(2) UTM的技术架构

- 1) 完全性内容保护 (CCP),对OSI模型中描述的所有层次的内容进行处理;
- 2) 紧凑型模式识别语言 (CPRL),是为了快速执行完全内容检测而设计的。
- 3) 动态威胁防护系统 (DTPS),是在传统的模式检测技术上结合未知威胁处理的防御体系.动态威胁防护系统可以将信息在防病毒、防火墙和入侵检测等子模块之间共享使用,以达到检测准确率和有效性的提升。这种技术是业界领先的一种处理技术,也是对传统安全威胁检测技术的一种颠覆。

4.5 入侵检测与防御系统概述

UTM基本组成结构如图4-12.企事业单位常见部署及应用如图4-13.



图4-12 UTM的基本组成结构



图4-13 UTM的部署及应用

讨论思考：

- (1) 入侵检测系统的主要功能是什么？
- (2) 网络安全面临的主要威胁类型有哪些？
- (3) 入侵检测技术发展的主要趋势有哪些？



4.7 本章小结

本章小结

本章概述了黑客的概念、形成与发展，简单介绍黑客产生的原因、攻击的方法、步骤；重点介绍常见的黑客攻防技术，包括网络端口扫描攻防、网络监听攻防、密码破解攻防、特洛伊木马攻防、缓冲区溢出攻防、拒绝服务攻击和其他攻防技术；同时讨论了防范攻击的具体措施和步骤；最后，概述了入侵检测系统的概念、功能、特点、分类、检测过程、常用检测技术和方法、实用入侵检测系统、统一威胁管理和入侵检测技术发展趋势等。

课后作业

练习与实践4

2 (1) (4) (5)

3 (1) ~ (5)

作业提交：手写拍照或电子文档，保存为pdf格式，命名“学号-姓名”
班长/学委打包发我QQ（97251651）或者邮箱（jingkun@ahu.edu.cn）

4.6 实验4 Sniffer网络安全检测

4.6.1 实验目的

利用Sniffer软件**捕获网络信息数据包**，然后通过**解码**进行**分析**。学会利用网络安全检测工具的实际操作方法，具体进行检测并写出结论。

4.6.2 实验要求及方法

■ 1. 实验环境

- 1) **硬件**：三台PC计算机。单机基本配置参见教材表4-1。
- 2) **软件**：操作系统Windows和 Sniffer 软件。

■ 2. 注意事项

本实验是在**虚拟实验环境**下**完成**，如要在真实的环境下完成，则网络设备应该选择集线器或交换机。如果是交换机，则在C机上要做端口镜像。

4.6 实验4 Sniffer网络安全检测

4.6.1 实验目的

利用Sniffer软件捕获网络信息数据包，然后通过解码进行分析。学会利用网络安全检测工具的实际操作方法，具体进行检测并写出结论。

4.6.2 实验要求及方法

■ 1. 实验环境

- 1) 硬件：三台PC计算机。单机基本配置参见教材表4-1。
- 2) 软件：操作系统Windows和 Sniffer 软件。

■ 2. 注意事项

本实验是在虚拟实验环境下完成，如要在真实的环境下完成，则网络设备应该选择集线器或交换机。如果是交换机，则在C机上要做端口镜像。

4.6 实验4 Sniffer网络安全检测

3. 实验方法

三台PC机的IP地址及任务分配见表4-2所示。

实验用时：2学时（课外可延伸）。

表4-1 实验设备基本配置要求

设备	名 称
内存	1G以上
CPU	2G以上
硬盘	40G以上
网卡	10M或者100M网卡

表4-2 三台PC机的IP地址及任务分配

设备	IP 地址	任务分配
A机	10.0.0.3	用户Zhao用此机登陆到FTP服务器
B机	10.0.0.4	已经搭建好的FTP服务器
C机	10.0.0.2	用户Tom在此机利用Sniffer软件捕获 Zhao的账号和密码

4.6 实验4 Sniffer网络安全检测

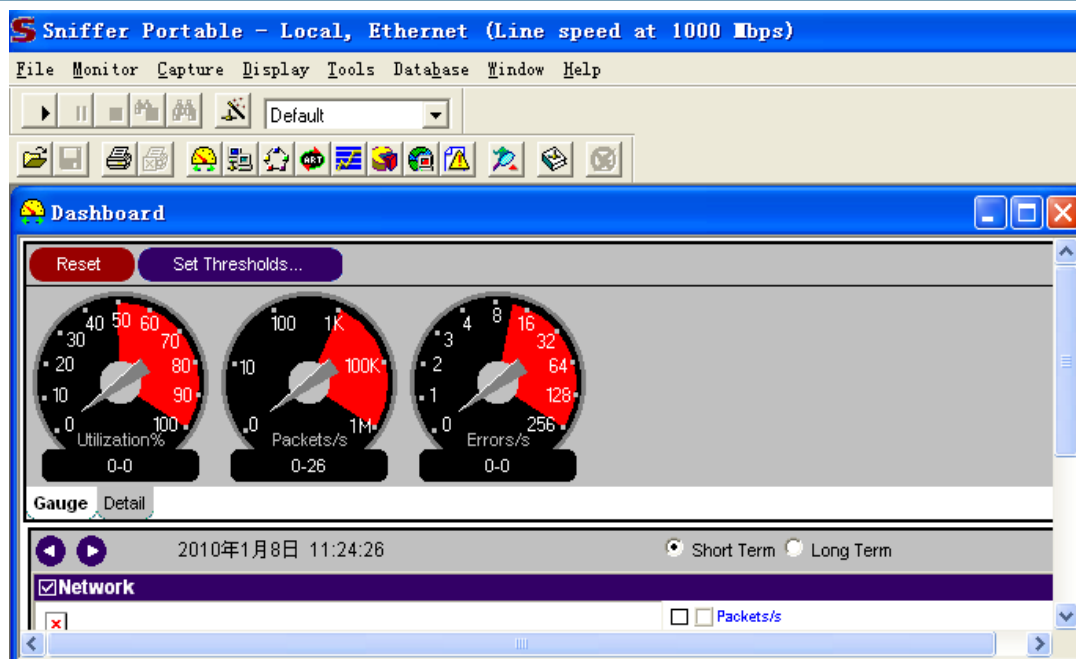
4.6.3 实验内容及步骤

■ 1. 实验内容

3台PC机,用户Zhao用已建好的账号在A机上登录到B机已搭建好的FTP服务器,Tom在用Sniffer捕获Zhao账号和密码。

■ 2. 实验步骤

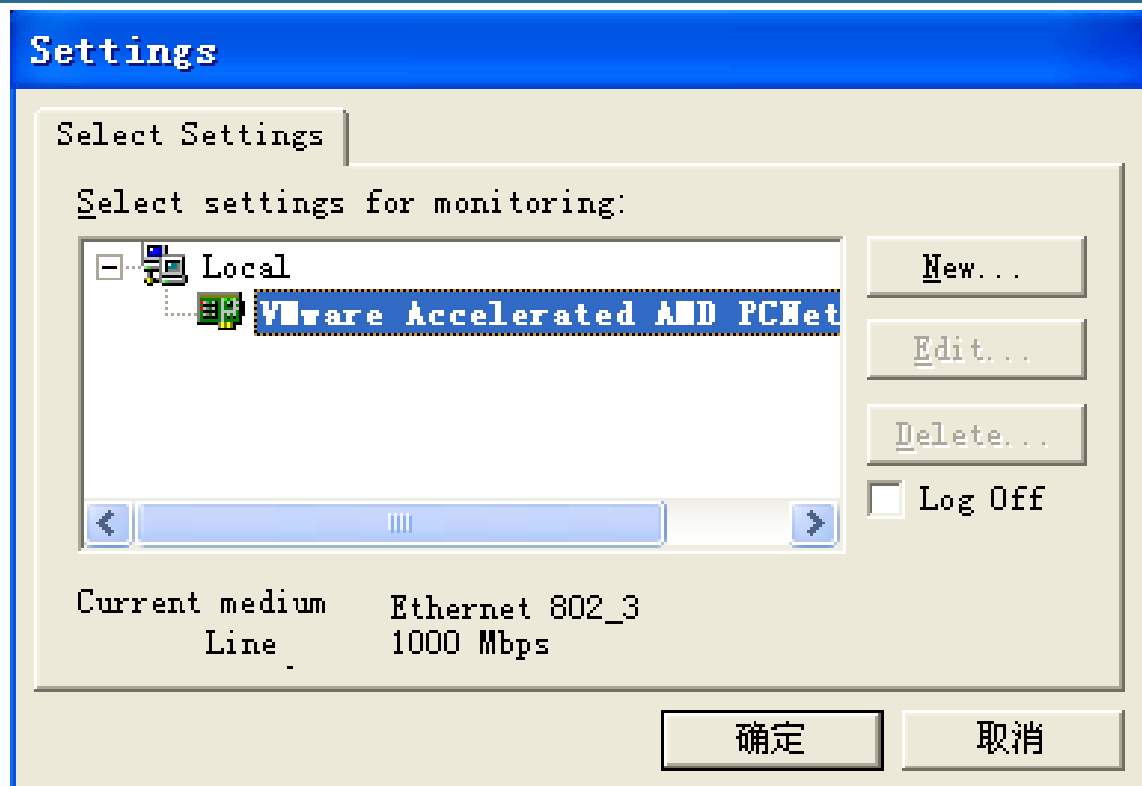
(1) 在C机上安装Sniffer,启动后进入主窗口。



4.6 实验4 Sniffer网络安全检测

4.6.3 实验内容及步骤

(2) 流量捕捉前,先选网卡, 确定从计算机的哪个网卡上接收数据,并把网卡设成混杂模式.将所有数据包接收后放入内存分析.设置方法:单击File→Select Settings命令,在弹出的对话框中设置,图4-10。



4.6 实验4 Sniffer网络安全检测

■ 2. 实验步骤

(3) 新建一个过滤器。设置方法为：

1) 单击Capture,选择Define Filter命令进入 Capture窗口。

2) 单击Profiles命令,打开Capture Profiles对话框;单击New按钮.在New Profiles Name文本框中输入ftp_test;单击OK。在Capture Profiles对话框中单击Done按钮, 如图4-11。



图4-16 新建过滤器窗口之一

4.6 实验4 Sniffer网络安全检测

■ 2. 实验步骤

(4) 在Define Filter对话框Address选项卡中, 设置地址类型为IP, 并在Station1和Station2中分别制定要捕获的地址对,如图。



图4-12 设置地址类型为IP

4.6 实验4 Sniffer网络安全检测

4.6.3 实验内容及步骤

■ 2. 实验步骤

- (5) 在“Define Filter”对话框的Advanced选项卡中，指定要捕获的协议为FTP。
- (6) 主窗口中，选择过滤器为ftp_test，然后单击“Capture”→“Start”，开始进行捕获。
- (7) 用户Zhao(赵先生)在A机上登录到FTP服务器。
- (8) 当用户用名字Zhao(赵先生)及密码登录成功时，Sniffer的工具栏会显示捕获成功的标志。
- (9) 利用专家分析系统进行解码分析，可以得到基本信息，如用户名、客户端IP等。

“十三五”国家重点出版规划
国家自然科学基金项目资助

上海市普通高校优秀教材奖
上海高校精品/优质在线课程

诚挚谢意！

网络安全技术及应用

国家智慧教育平台

国家智慧教育平台—上海精品/优质在线课程

(第5版, 慕课微课版, 新形态)



网络安全技术